

TRƯỜNG ĐẠI HỌC GIAO THÔNG VẬN TẢI
KHOA CÔNG NGHỆ THÔNG TIN

-----o0o-----



BÁO CÁO BÀI TẬP LỚN
HỌC PHẦN: PROJECT 1-1-1-24(N08)
NHÓM 13
XÂY DỰNG HỆ THỐNG GIÁM SÁT MẠNG VỚI
WAZUH

Giảng viên hướng dẫn:

Thầy: Nguyễn Quốc Tuấn

Sinh viên thực hiện:

1	Lê Đình Dũng	211240089
2	Chu Ngọc Anh	211210503
3	Trần Quang Anh	211210126
4	Nguyễn Quốc Tú	211200619

Hà Nội, Tháng 09 Năm 2024

-----o0o-----

MỤC LỤC

DANH MỤC KÝ HIỆU VÀ VIẾT TẮT.....	4
DANH MỤC BẢNG.....	4
DANH MỤC HÌNH ẢNH.....	4
LỜI MỞ ĐẦU.....	6
CHƯƠNG I. GIỚI THIỆU CHUNG.....	7
1.1.Bối cảnh hiện nay:.....	7
1.2.Bài toán đặt ra:.....	8
1.2.Các giải pháp:.....	10
1.2.1. Splunk Enterprise Security.....	10
1.2.2. OSSEC.....	11
1.2.2. Alien Vault OSSIM.....	12
1.2.4. Wazuh.....	13
1.4.So sánh các giải pháp:.....	14
CHƯƠNG II. GIỚI THIỆU VỀ WAZUH.....	18
2.1.Tổng quan về XDR và SIEM:.....	18
2.1.1.XDR là gì ?.....	18
2.1.2. SIEM là gì ?.....	19
2.2. Những tính năng nổi bật của Wazuh:.....	20
2.2.1. Thu thập và Phân tích Nhật ký (SIEM):.....	20
2.2.2. Phát hiện và Phản hồi Mối đe dọa Nâng cao (XDR):.....	20
2.2.3. Các Tính năng Bảo mật khác:.....	21
2.2.4. Tích hợp Linh hoạt và Khả năng Mở rộng:.....	21
2.3. Kiến trúc và các thành phần của Wazuh:.....	22
2.3.1. Wazuh Agent:.....	22
2.3.2. Wazuh Manager (Server):.....	22
2.3.3. Wazuh Indexer:.....	23
2.3.4. Wazuh Dashboard:.....	23
2.3.5. Các thành phần hỗ trợ khác:.....	23
2.4. Luật trong Wazuh:.....	25
2.4.1. Các cấp độ luật của Wazuh:.....	25
2.4.2. Phân loại luật:.....	29
2.5. Wazuh hoạt động như thế nào ?.....	30
Bước 1. Thu thập dữ liệu:.....	30
Bước 2. Truyền dữ liệu:.....	30
Bước 3. Xử lý và phân tích dữ liệu:.....	30

<i>Bước 4. Lưu trữ và lập chỉ mục dữ liệu:</i>	31
<i>Bước 5. Trực quan hóa và tương tác:</i>	31
CHƯƠNG III. THỬ NGHIỆM VÀ ĐÁNH GIÁ	32
3.1. Xây dựng hệ thống:	32
3.2. Kịch bản 01:	33
3.3. Kịch bản 02:	37
3.4. Kịch bản 03:	45
3.5. Đánh giá và kết luận:	49
TÀI LIỆU THAM KHẢO	50
PHỤ LỤC	51
1. Cài đặt Wazuh:	51
2. Cài đặt Agent:	52

DANH MỤC KÝ HIỆU VÀ VIẾT TẮT

MFA	Multi-Factor Authentication
XDR	Extended Detection and Response
SIEM	Security Information & Event Management
IDS	Instruction Dectection System
HIDS	Host-base Instruction Dectection System
GDPR	General Data Protection Regulation
HIPAA	Health Insurance Portability and Accountability Act
PCI-DSS	Payment Card Industry Data Security Standard
OTX	Open Threat Exchange
SOAR	Security Orchestration Automation and Response
SSH	Secure Shell

DANH MỤC BẢNG

Bảng 1. Bảng so sánh các thông số của các giải pháp.....	16
Bảng 2.Các cấp độ luật trong Wazuh.....	27
Bảng 3.Cấu hình máy ảo thử nghiệm.....	32
Bảng 4.tài nguyên tham khảo trước khi cài Wazuh	51

DANH MỤC HÌNH ẢNH

Hình 1. Các chức năng cần có cho hệ thống an ninh	8
Hình 2. Splunk Dashboard	10
Hình 3. OSSEC Dashboard	11
Hình 4. Alien Vault OSSIM Dashboard.....	12
Hình 5. Wazuh Dashboard	13
Hình 6. Mô hình XDR.....	18
Hình 7. Mô hình SIEM.....	19
Hình 8. Wazuh Architechture.....	22
Hình 9. How Wazuh work.....	30
Hình 10. Mô hình thử nghiệm.....	32
Hình 11. Cấu hình trong file ossec.conf.....	33
Hình 12. Dashboard lỗi hỏng hệ thống.....	34
Hình 13. Log của một lỗi hỏng được phát hiện (1)	34
Hình 14. Log của một lỗi hỏng được phát hiện (2)	35
Hình 15. Thông tin JSON của lỗi hỏng.....	36
Hình 16. Đăng ký nhận API của Virus Total miễn phí	37
Hình 17. Tạo file trong thư mục.....	38
Hình 18. Thông tin hiển thị việc thêm file trên dashboard (1)	38
Hình 19. Thông tin hiển thị việc thêm file trên dashboard (2)	39
Hình 20. Log thêm file được ghi lại trên hệ thống.....	40
Hình 21. Nội dung dữ liệu được viết trong file.....	41
Hình 22. Virus Total tự động kiểm tra mã độc trong file mới được thêm	41
Hình 23. Sửa nội dung tệp tin	42

Hình 24. Thông tin về việc thay đổi nội dung file	42
Hình 25. Thêm thư mục chứa mã độc	43
Hình 26. Virus Total tự động phát hiện mã độc trong thư mục mới thêm	43
Hình 27. Kiểm tra thông tin trên Virus Total	44
Hình 28. Kiểm tra kết nối mạng giữa máy Attacker và ubuntu agent.....	46
Hình 29. Thực hiện SSH từ máy Attacker đến máy agent	46
Hình 30. Thực hiện giả định tấn công SSH brute force bằng Hydra.....	47
Hình 31. Attacker thực hiện ping đến agent.....	47
Hình 32. Attacker SSH đến agent	47
Hình 33. Log của thông tin chặn IP của Attacker (1).....	48
Hình 34. Log của thông tin chặn IP của Attacker (2).....	48
Hình 35. Thông báo sau khi cài đặt hoàn tất	51
Hình 36. Thao tác khi thêm 1 thiết bị để giám sát trên Wazuh (1)	52
Hình 37. Thao tác khi thêm 1 thiết bị để giám sát trên Wazuh (2)	53

LỜI MỞ ĐẦU

Trong kỷ nguyên số, khi công nghệ thông tin trở thành xương sống của mọi hoạt động, từ kinh doanh, giáo dục đến y tế và chính phủ, an ninh mạng nổi lên như một thách thức cấp bách. Các cuộc tấn công mạng ngày càng tinh vi và đa dạng, đe dọa nghiêm trọng đến tính bảo mật, toàn vẹn và khả năng sẵn sàng của hệ thống thông tin. Từ những mã độc tống tiền (ransomware) làm tê liệt hoạt động kinh doanh, đến các cuộc tấn công từ chối dịch vụ (DDoS) gây gián đoạn dịch vụ trực tuyến, hay những lỗ hổng zero-day âm thầm khai thác thông tin nhạy cảm, tất cả đều tạo nên một bức tranh đầy thách thức về an ninh mạng.

Giữa bối cảnh đó, giám sát an ninh mạng đóng vai trò then chốt trong việc bảo vệ các tổ chức khỏi những mối đe dọa tiềm ẩn. Một hệ thống giám sát hiệu quả không chỉ giúp phát hiện sớm các cuộc tấn công, mà còn cung cấp thông tin chi tiết về hoạt động của hệ thống, hỗ trợ quá trình điều tra và ứng phó sự cố, đồng thời giúp các tổ chức tuân thủ các quy định về bảo mật. Tuy nhiên, việc xây dựng và vận hành một hệ thống giám sát toàn diện đòi hỏi sự đầu tư đáng kể về công nghệ, kiến thức chuyên môn và nguồn lực.

Báo cáo này sẽ tập trung vào việc nghiên cứu và triển khai một hệ thống giám sát an ninh mạng hiệu quả và tiết kiệm chi phí dựa trên nền tảng Wazuh - một giải pháp mã nguồn mở mạnh mẽ. Nhóm 13 chúng em sẽ đi sâu vào phân tích các yêu cầu giám sát, thiết kế kiến trúc hệ thống, và đánh giá hiệu quả của Wazuh trong việc bảo vệ hệ thống thông tin khỏi các mối đe dọa an ninh mạng.

Nhân đây, chúng em xin chân thành cảm ơn sự giúp đỡ tận tình của giảng viên, thầy Nguyễn Quốc Tuấn. Song, do kiến thức và kinh nghiệm còn nhiều hạn chế, việc tìm hiểu và nghiên cứu về đề tài này của nhóm chúng em sẽ không tránh được những thiếu sót. Rất mong được thầy và các bạn đóng góp ý kiến để đề tài của chúng em được hoàn thiện hơn.

Chúng em xin chân thành cảm ơn!

CHƯƠNG I. GIỚI THIỆU CHUNG

1.1. Bối cảnh hiện nay:

Trong những năm gần đây, an toàn thông tin trên thế giới ngày càng trở nên phức tạp, với nhiều cuộc tấn công mạng quy mô lớn gây ra thiệt hại nghiêm trọng. Các sự kiện này không chỉ ảnh hưởng đến các cá nhân, tổ chức mà còn đe dọa sự ổn định của các quốc gia.

Năm 2020: Cuộc tấn công chuỗi cung ứng SolarWinds Vụ tấn công vào phần mềm quản lý Orion của SolarWinds đã khiến khoảng 18.000 khách hàng bị ảnh hưởng, bao gồm các cơ quan chính phủ Mỹ và các công ty lớn như Microsoft, FireEye. Tin tặc APT29, liên kết với Nga, đã cài mã độc "Sunburst" vào bản cập nhật phần mềm, cho phép truy cập trái phép vào hệ thống. Vụ việc phơi bày lỗ hổng nghiêm trọng trong chuỗi cung ứng phần mềm, đòi hỏi cải tiến lớn trong an ninh mạng toàn cầu.

Năm 2021: Tấn công ransomware vào Colonial Pipeline Hệ thống dẫn dầu lớn nhất nước Mỹ bị nhóm tin tặc DarkSide sử dụng ransomware tấn công vào tháng 5/2021, buộc công ty phải trả 4,4 triệu USD tiền chuộc. Cuộc tấn công đã gây ra khủng hoảng nhiên liệu trên bờ Đông Hoa Kỳ và làm nổi bật mối đe dọa đối với cơ sở hạ tầng quan trọng, thúc đẩy chính phủ Mỹ tăng cường bảo mật mạng.

Năm 2022: Nhóm Lapsus\$ tấn công các tập đoàn công nghệ Nhóm tin tặc Lapsus\$ đã thực hiện các cuộc tấn công táo bạo vào các công ty lớn như Nvidia, Samsung, và Microsoft. Sử dụng kỹ thuật xã hội hóa và mua thông tin đăng nhập từ chợ đen, nhóm này đánh cắp và công khai dữ liệu nhạy cảm trên Telegram. Các cuộc tấn công của Lapsus\$ nhấn mạnh nguy cơ từ yếu tố con người và sự cần thiết của các biện pháp xác thực đa yếu tố (MFA).

Năm 2023: Cuộc tấn công ransomware vào Royal Mail Tháng 1/2023, hệ thống bưu chính quốc tế của Royal Mail bị tấn công bởi nhóm LockBit, làm gián đoạn dịch vụ tại 11.500 chi nhánh. Cuộc tấn công gây thiệt hại lớn về kinh tế và suy giảm niềm tin của công chúng. Royal Mail buộc phải đầu tư lớn vào cải thiện an ninh mạng và hợp tác quốc tế để đối phó với mối đe dọa.

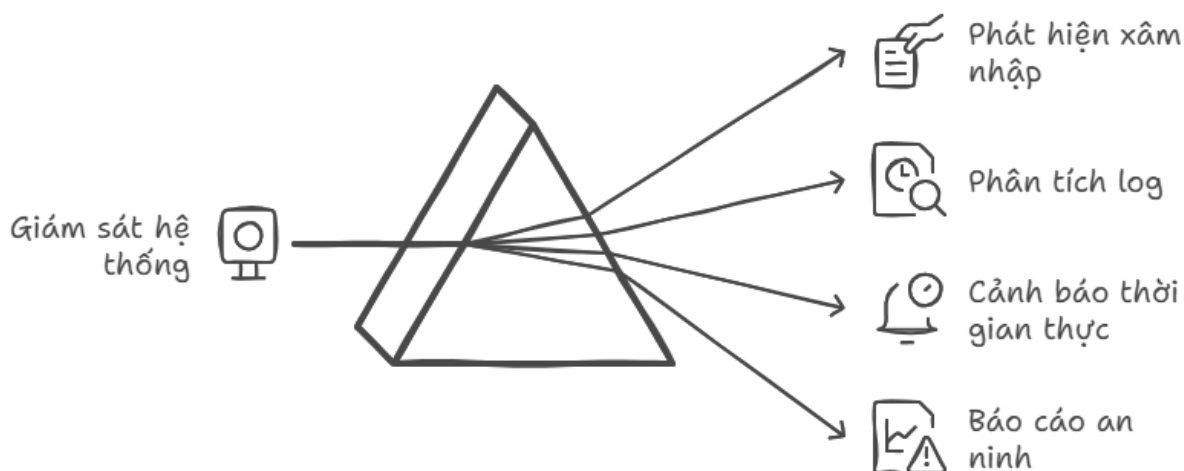
Năm 2024: Cuộc tấn công Midnight Blizzard vào Microsoft Hệ thống nội bộ của Microsoft bị nhóm NOBELIUM, được cho là có liên kết với Nga, tấn công bằng kỹ thuật "password spray" vào tháng 1/2024. Cuộc tấn công nhắm vào hệ thống email nội bộ, gây rò rỉ dữ liệu nhạy cảm và làm giảm niềm tin của khách hàng. Microsoft đã triển khai các biện pháp khẩn cấp và cảnh báo toàn ngành về các lỗ hổng bảo mật trong hệ thống không được bảo vệ bằng xác thực đa yếu tố.

Những sự kiện trên cho thấy không một tổ chức hay cá nhân nào có thể hoàn toàn miễn nhiễm với các mối đe dọa mạng. Việc tăng cường nhận thức về an ninh mạng, đầu tư vào giải pháp bảo mật hiện đại và hợp tác quốc tế là yếu tố then chốt để bảo vệ không gian mạng toàn cầu

1.2. Bài toán đặt ra:

Từ bối cảnh an ninh mạng đầy thách thức nêu trên, việc xây dựng một hệ thống giám sát an ninh mạng hiệu quả là yêu cầu cấp thiết đối với mọi tổ chức, doanh nghiệp. Hệ thống này cần đáp ứng được các yêu cầu sau:

- **Giám sát hoạt động của hệ thống:** Hệ thống cần thu thập và phân tích dữ liệu từ nhiều nguồn khác nhau như log máy chủ, thiết bị mạng, ứng dụng, ... để theo dõi hoạt động của hệ thống theo thời gian thực, phát hiện các biểu hiện bất thường hoặc các dấu hiệu của cuộc tấn công mạng.
- **Phát hiện xâm nhập:** Hệ thống cần có khả năng nhận diện các hoạt động xâm nhập trái phép vào hệ thống, cảnh báo kịp thời cho quản trị viên để xử lý.
- **Phân tích log tập trung:** Hệ thống cần tổng hợp log từ nhiều nguồn khác nhau, lưu trữ và phân tích log để xác định nguyên nhân gốc rễ của sự cố bảo mật, hỗ trợ điều tra và phòng ngừa các cuộc tấn công trong tương lai.
- **Cảnh báo và thông báo:** Hệ thống cần cung cấp các cảnh báo thời gian thực về các sự kiện bảo mật quan trọng, gửi thông báo đến quản trị viên thông qua các kênh như email, SMS,...
- **Báo cáo và thống kê:** Hệ thống cần cung cấp các báo cáo về tình hình an ninh mạng, thống kê các sự cố bảo mật, giúp quản trị viên đánh giá hiệu quả của hệ thống và đưa ra các quyết định phòng ngừa phù hợp.
- ...



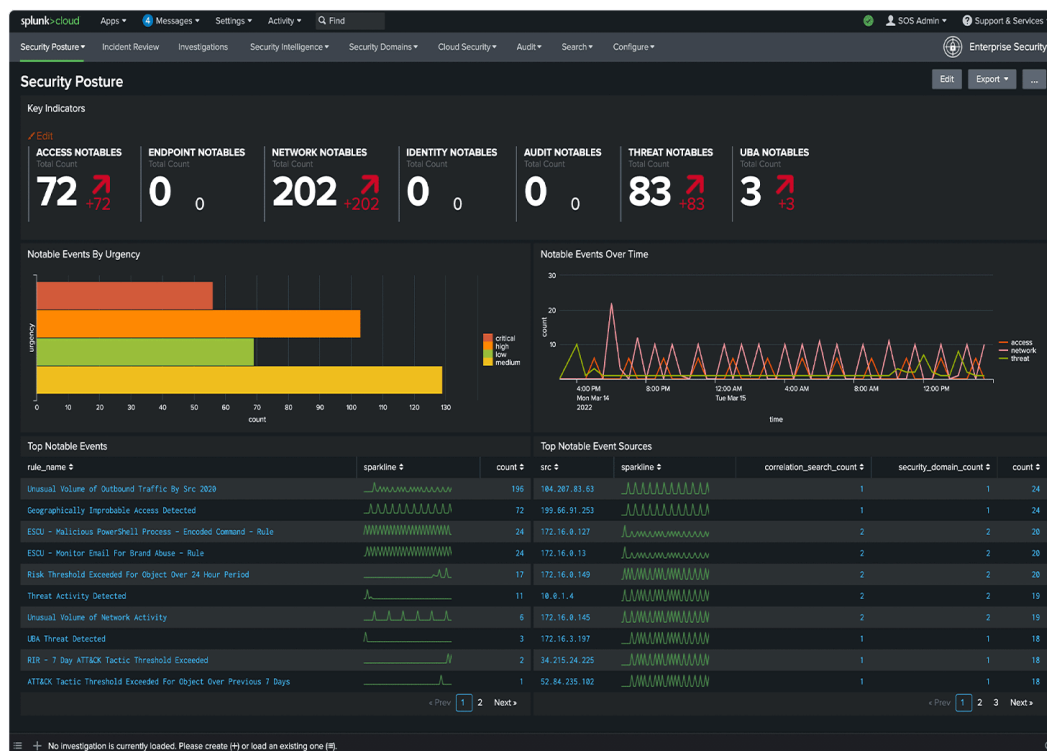
Hình 1. Các chức năng cần có cho hệ thống an ninh

Tóm lại, hệ thống giám sát an ninh mạng cần phải có khả năng giám sát toàn diện, phát hiện sớm các mối đe dọa, phân tích chi tiết sự cố, và hỗ trợ quản trị viên trong việc đưa ra quyết định ứng phó kịp thời và hiệu quả..

Để giải quyết bài toán đặt ra cho hệ thống giám sát an ninh mạng mà chúng ta nêu ở trên, thị trường hiện nay có rất nhiều giải pháp khác nhau, cả thương mại và mã nguồn mở, mỗi loại đều có những ưu điểm và nhược điểm riêng. Trong phần tiếp theo, chúng ta sẽ cùng tìm hiểu về một số giải pháp tiêu biểu, từ đó đưa ra lựa chọn phù hợp nhất cho hệ thống của mình.

1.2. Các giải pháp:

1.2.1. Splunk Enterprise Security



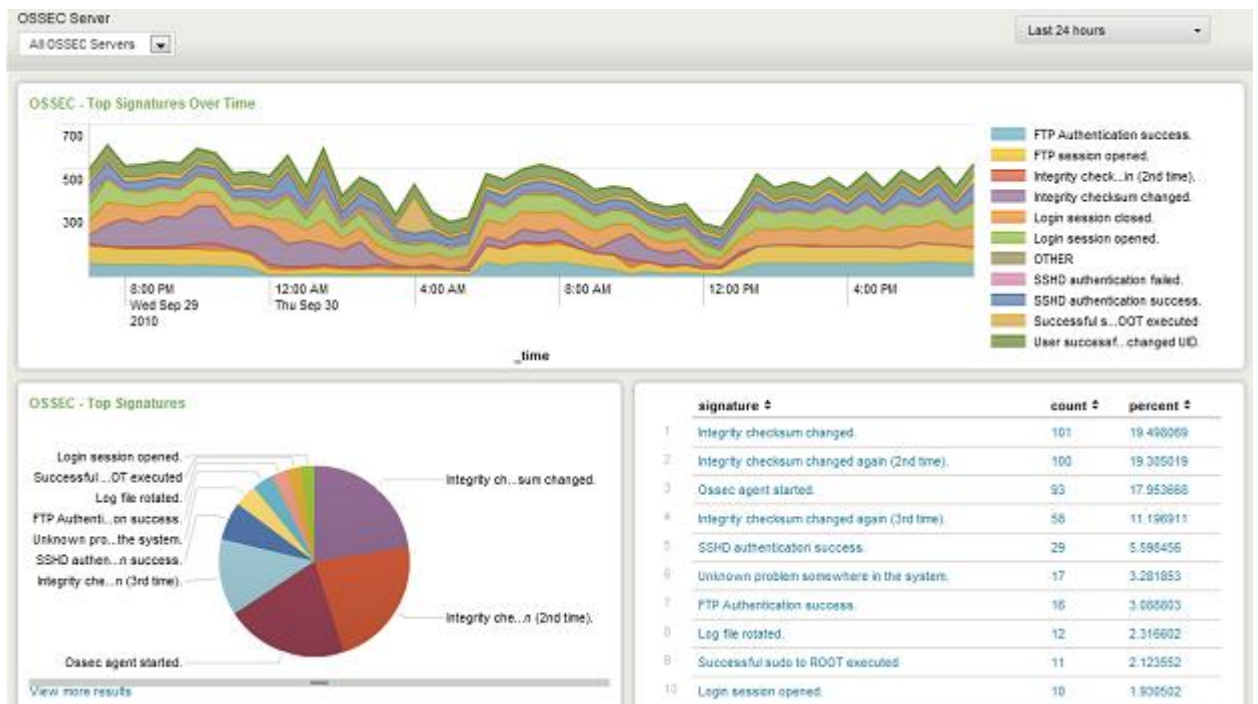
Hình 2. Splunk Dashboard

Một nền tảng SIEM (Security Information and Event Management) thương mại mạnh mẽ, cung cấp khả năng thu thập, phân tích và tương quan dữ liệu bảo mật từ nhiều nguồn khác nhau.

Splunk ES giúp tập hợp và phân tích dữ liệu từ nhiều nguồn khác nhau như tường lửa, hệ thống phát hiện xâm nhập, hệ thống ngăn ngừa xâm nhập, thiết bị mạng và các ứng dụng khác để tạo ra cái nhìn tổng quan về tình trạng bảo mật của hệ thống

Splunk ES hỗ trợ các tổ chức duy trì và báo cáo tuân thủ các quy định về an ninh như GDPR, HIPAA và PCI-DSS

1.2.2. OSSEC



Hình 3. OSSEC Dashboard

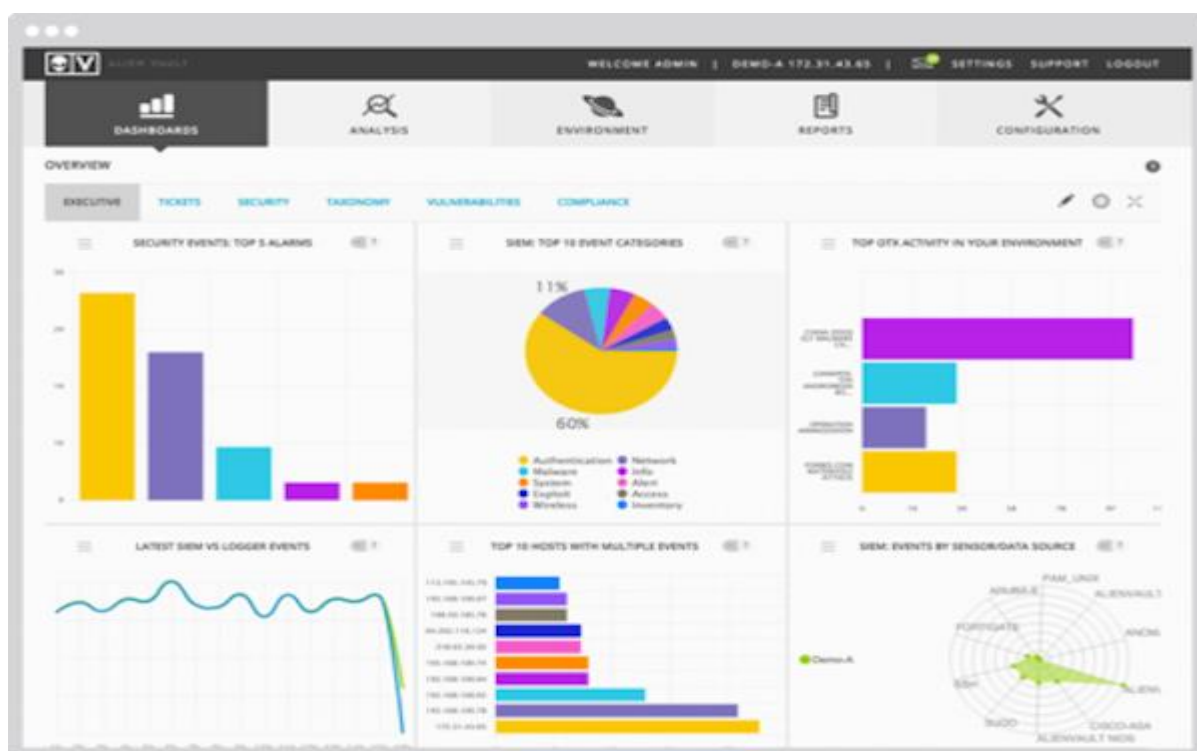
Một hệ thống phát hiện xâm nhập mã nguồn mở (HIDS) tập trung vào việc giám sát tính toàn vẹn của tập tin và phát hiện các thay đổi trái phép trong hệ thống.

Các chức năng chính của OSSEC bao gồm giám sát tệp, phân tích nhật ký, phát hiện rootkit, giám sát registry, tự động phản hồi

Mô hình kiến trúc của OSSEC hoạt động theo mô hình phân tán, trong đó các agent được cài đặt trên các máy chủ hệ thống đầu cuối, gửi dữ liệu về máy chủ OSSEC để phân tích

Đây là một công cụ mạnh mẽ, dễ triển khai và được sử dụng phổ biến trong các môi trường tài chính, chính phủ, y tế

1.2.2. Alien Vault OSSIM



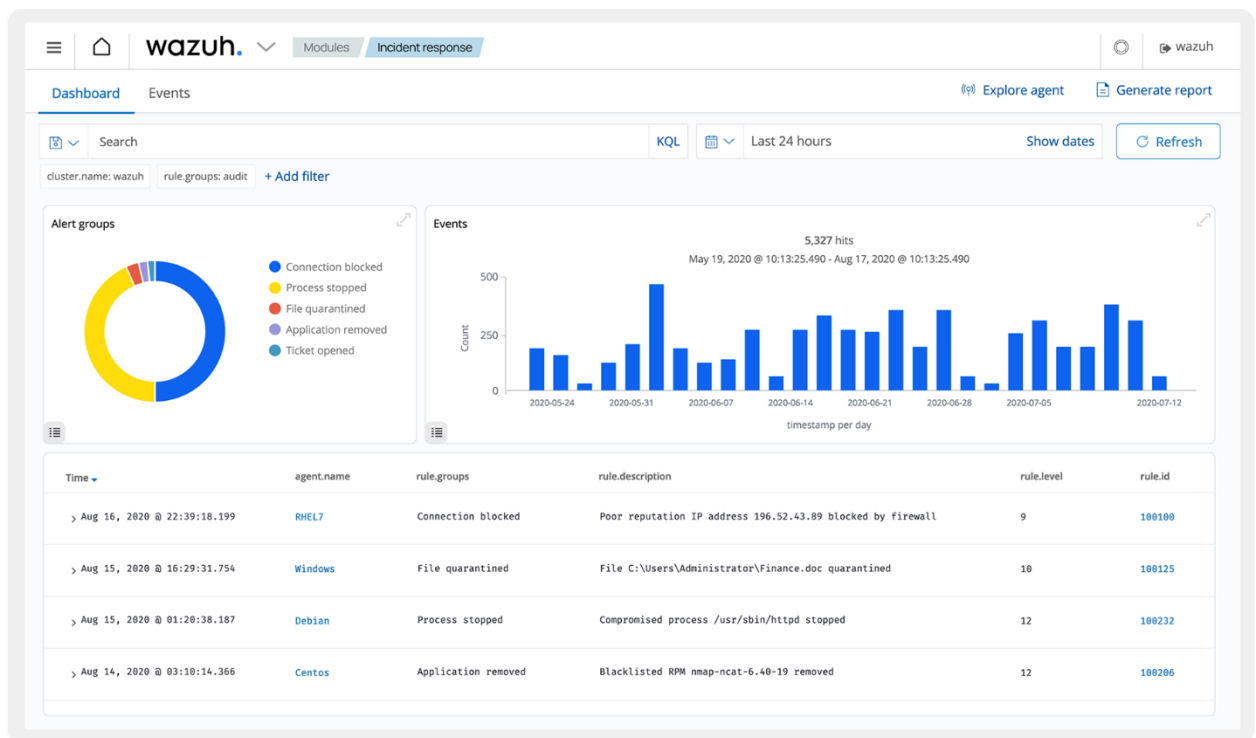
Hình 4. Alien Vault OSSIM Dashboard

Là một mã nguồn mở quản lý thông tin và sự kiện an ninh bao gồm tập hợp các công cụ được thiết kế để trợ giúp các nhân viên quản trị phát hiện và phòng chống xâm nhập

OSSIM bao gồm các thành phần SIEM chính, cụ thể là thu thập, xử lý và chuẩn hóa dữ liệu. Quan trọng nhất OSSIM có sự tương quan sự kiện

OSSIM tích hợp nhiều các mã nguồn mở vào hệ thống như: Snort, OSSEC, OpenVAS,...

1.2.4. Wazuh



Hình 5. Wazuh Dashboard

Wazuh là một nền tảng bảo mật mã nguồn mở toàn diện, được thiết kế để giúp các tổ chức bảo vệ hệ thống và dữ liệu của họ khỏi các mối đe dọa an ninh mạng ngày càng gia tăng. Với sự kết hợp giữa khả năng phát hiện và phản ứng mở rộng (XDR) và quản lý thông tin và sự kiện bảo mật (SIEM), Wazuh cung cấp một giải pháp giám sát, phân tích và ứng phó sự cố tập trung, giúp các doanh nghiệp chủ động đối phó với các cuộc tấn công tinh vi.

1.4. So sánh các giải pháp:

Tiêu chí	Wazuh	Splunk Enterprise Security	OSSEC	AlienVault OSSIM
1. License	Mã nguồn mở (Elastic License)	Trả phí (Có bản dùng thử)	Mã nguồn mở (GPLv2)	Mã nguồn mở (GPLv3)
2. Triển khai				
2.1 Cloud	Có	Có	Có (Thông qua giải pháp của bên thứ ba)	Có (Thông qua giải pháp bên thứ 3)
2.2 On-premise	Có	Có	Có	Có
3. Hỗ trợ đa nền tảng (Windows, Linux, MacOS)	Có	Có	Có	Có (chủ yếu hỗ trợ Linux)
4. Khả năng thu thập và phân tích log				
4.1 Tích hợp với các nguồn logs	Rộng rãi	Rất rộng rãi (Hỗ trợ đa dạng nguồn dữ liệu)	Rộng rãi	Rộng rãi
4.2 Hỗ trợ các chuẩn định dạng logs	Đa dạng	Đa dạng	Đa dạng	Đa dạng
4.3 Phân tích logs theo thời gian thực	Có	Có	Có	Có
5. Phát hiện và phản ứng với mối đe dọa				
5.1 Các công cụ phát hiện mối đe dọa	Tích hợp sẵn các quy tắc phát hiện, hỗ trợ SIEM	Đa dạng, mạnh mẽ, hỗ trợ Machine Learning	Tích hợp sẵn các quy tắc phát hiện	Tích hợp với cơ sở dữ liệu threat intelligence của OTX

5.2 Khả năng tùy chỉnh quy tắc phát hiện và cảnh báo	Có	Có (Linh hoạt, mạnh mẽ)	Có	Có (Linh hoạt)
5.3 Tính năng tự động phản hồi	Có (Giới hạn)	Có (Mạnh mẽ, tích hợp với SOAR)	Có (Giới hạn)	Có
6. Quản lý sự tuân thủ				
6.1 Tính năng báo cáo tuân thủ theo các tiêu chuẩn phổ biến	Có	Có (Mạnh mẽ, đa dạng)	Có (Giới hạn)	Có
6.2 Khả năng audit và theo dõi các hoạt động trong tổ chức	Có	Có (Mạnh mẽ)	Có	Có
6.3 Công cụ hỗ trợ phân tích sự cố bảo mật liên quan đến việc tuân thủ	Có	Có (Mạnh mẽ)	Có (Giới hạn)	Có (Mạnh mẽ)
7. Trực quan hóa và báo cáo				
7.1 Giao diện người dùng (UI) thân thiện và dễ sử dụng	Thân thiện	Rất thân thiện, dễ sử dụng	Giao diện web	Giao diện web
7.2 Khả năng tùy chỉnh báo cáo và dashboard	Có (Thông qua Kibana)	Có (Mạnh mẽ, linh hoạt)	Có (Giới hạn)	Có
7.3 Cung cấp cảnh báo tức	Có (Thông qua Kibana)	Có (Đa dạng, trực quan)	Có (Cơ bản)	Có (Đa dạng, trực quan)

thì với biểu đồ, đồ thị minh họa				
8. Khả năng tích hợp				
8.1 Hỗ trợ API cho các ứng dụng và công cụ bên ngoài	Có (linh hoạt)	Có (Rộng rãi, linh hoạt)	Có	Có
8.2 Khả năng tích hợp với các hệ thống quản lý bảo mật khác	Có	Có (Rộng rãi)	Có	Có
9. Use-case	phù hợp cho các tổ chức muốn một giải pháp mã nguồn mở linh hoạt với khả năng tùy chỉnh cao, có thể mở rộng cho các triển khai vừa và lớn	phù hợp cho các doanh nghiệp lớn cần xử lý lượng dữ liệu lớn và có ngân sách cao.	phù hợp nhất cho các triển khai nhỏ hoặc làm thành phần trong một stack bảo mật lớn hơn.	Phù hợp cho các tổ chức vừa và nhỏ muốn một giải pháp SIEM all-in-one mã nguồn mở và miễn phí.có thể mở rộng cho các triển khai vừa và lớn
10. Cộng đồng và hỗ trợ	có cộng đồng mã nguồn mở active	Splunk có hỗ trợ chuyên nghiệp 24/7 và cộng đồng người dùng lớn.	có cộng đồng mã nguồn mở active	có cộng đồng người dùng và hỗ trợ từ AT&T Cybersecurity

Bảng 1. Bảng so sánh các thông số của các giải pháp

- **Lựa chọn Wazuh**

Wazuh nổi bật như một giải pháp cân bằng giữa tính năng, chi phí và khả năng sử dụng. Wazuh vừa cung cấp các tính năng giám sát an ninh mạng toàn diện, vừa có chi phí triển khai thấp và dễ dàng triển khai. Với những ưu điểm vượt trội này, Wazuh là một lựa chọn phù hợp để xây dựng hệ thống giám sát an ninh mạng hiệu quả và tiết kiệm chi phí.

CHƯƠNG II. GIỚI THIỆU VỀ WAZUH

wazuh.

2.1. Tổng quan về XDR và SIEM:

2.1.1. XDR là gì ?



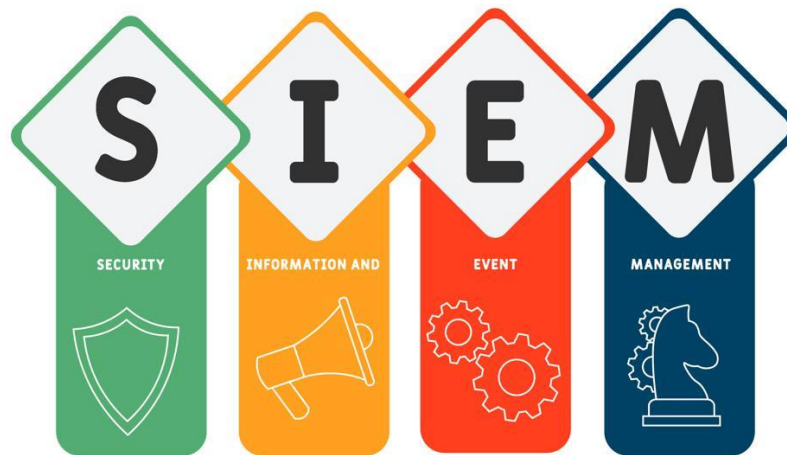
Hình 6. Mô hình XDR

- XDR (Extended Detection and Response) đại diện cho một bước tiến vượt bậc trong lĩnh vực giám sát và ứng phó bảo mật. Vượt qua các giải pháp truyền thống, XDR tích hợp dữ liệu từ đa dạng nguồn như điểm cuối, mạng, đám mây, email và danh tính, mang đến khả năng hiển thị toàn diện và phát hiện mối đe dọa trên diện rộng.
- Sức mạnh của XDR nằm ở khả năng tương quan và phân tích nâng cao, tận dụng trí tuệ nhân tạo (AI) và học máy để liên kết các sự kiện bảo mật rời rạc, từ đó phát hiện các mối đe dọa phức tạp và chuỗi tấn công đa chiều. Hơn nữa, XDR² cho phép tự động hóa các quy trình ứng phó, giảm thiểu đáng kể thời gian phản hồi và tác động của các cuộc tấn công.

+ Chức năng chính của XDR :

- Tích hợp và tương quan dữ liệu từ nhiều nguồn.
- Phát hiện và ngăn chặn mối đe dọa bằng AI và học máy.
- Điều tra và ứng phó sự cố nhanh chóng.
- Tự động hóa các quy trình ứng phó.
- Báo cáo và trực quan hóa dữ liệu bảo mật.

2.1.2. SIEM là gì ?



Hình 7. Mô hình SIEM

- SIEM (Security Information and Event Management) đóng vai trò trung tâm trong việc quản lý thông tin và sự kiện bảo mật. Bằng cách thu thập và lưu trữ nhật ký từ nhiều nguồn khác nhau, SIEM tạo ra một kho dữ liệu tập trung, làm nền tảng cho phân tích và điều tra bảo mật.

- Thông qua các quy tắc tương quan tinh vi, SIEM có khả năng xác định các mối quan hệ giữa các sự kiện bảo mật, từ đó phát hiện các mẫu tấn công tiềm ẩn. Bên cạnh đó, SIEM còn cung cấp các báo cáo chi tiết, hỗ trợ các tổ chức chứng minh sự tuân thủ các quy định bảo mật.

+ Chức năng chính của SIEM:

- Thu thập và tổng hợp dữ liệu nhật ký từ nhiều nguồn.
- Tương quan và phân tích sự kiện để phát hiện mối đe dọa.
- Cảnh báo và thông báo về các sự kiện bảo mật.
- Báo cáo và trực quan hóa tình trạng bảo mật.
- Lưu trữ và truy vấn dữ liệu lịch sử.
- Hỗ trợ tuân thủ các quy định bảo mật.

2.2. Những tính năng nổi bật của Wazuh:

Wazuh, một giải pháp tiên tiến trong lĩnh vực bảo mật, kết hợp liền mạch công nghệ XDR (Extended Detection and Response) và SIEM (Security Information and Event Management). Sự tích hợp độc đáo này tạo nên một hệ thống bảo mật toàn diện, cung cấp một loạt tính năng vượt trội:

2.2.1. Thu thập và Phân tích Nhật ký (SIEM):

- **Thu thập đa nguồn:** Wazuh thu thập nhật ký từ nhiều nguồn khác nhau, bao gồm hệ thống, ứng dụng, thiết bị mạng và nhiều hơn nữa, cung cấp một cái nhìn toàn diện về hoạt động của môi trường CNTT của bạn.
- **Phân tích chuyên sâu:** Thông qua phân tích và tương quan các sự kiện từ nhiều nguồn, Wazuh giúp bạn xác định các mối đe dọa tiềm ẩn, các mẫu tấn công và các hành vi bất thường.
- **Tìm kiếm và điều tra:** Với khả năng tìm kiếm và điều tra mạnh mẽ, Wazuh cho phép bạn nhanh chóng truy vết và phân tích các sự kiện bảo mật, hỗ trợ quá trình điều tra và xử lý sự cố.
- **Báo cáo và cảnh báo:** Wazuh cung cấp các báo cáo tùy chỉnh và cảnh báo theo thời gian thực, giúp bạn luôn nắm bắt được tình hình an ninh và kịp thời phản ứng trước các sự cố.

2.2.2. Phát hiện và Phản hồi Mối đe dọa Nâng cao (XDR):

- **Tương quan và phân tích dữ liệu đa chiều:** Wazuh không chỉ thu thập dữ liệu mà còn thực hiện tương quan và phân tích sâu giữa chúng, giúp phát hiện các mối đe dọa phức tạp và các mẫu tấn công ẩn mình.
- **Phát hiện mối đe dọa nâng cao:** Sử dụng các kỹ thuật tiên tiến như UEBA, học máy, phân tích các lỗ hổng và mối đe dọa, Wazuh có khả năng nhận diện các cuộc tấn công tinh vi, bao gồm cả các mối đe dọa chưa từng được biết đến (zero-day).
- **Phản ứng tự động và điều phối:** Khi phát hiện mối đe dọa, Wazuh có thể tự động thực hiện các hành động phản hồi như cách ly máy tính bị nhiễm, chặn IP độc hại hoặc thực thi các quy trình khắc phục sự cố, giảm thiểu thời gian phản hồi và thiệt hại.
- **Khả năng hiển thị và điều tra tập trung:** Giao diện tập trung của Wazuh giúp bạn giám sát, phân tích và điều tra các sự cố bảo mật trên toàn hệ thống một cách dễ dàng và hiệu quả.

- **Bảo vệ khối lượng công việc đám mây và container:** Wazuh tích hợp với các dịch vụ đám mây và môi trường container, cho phép bạn giám sát và bảo vệ toàn diện các tài nguyên đám mây và ứng dụng container hóa.

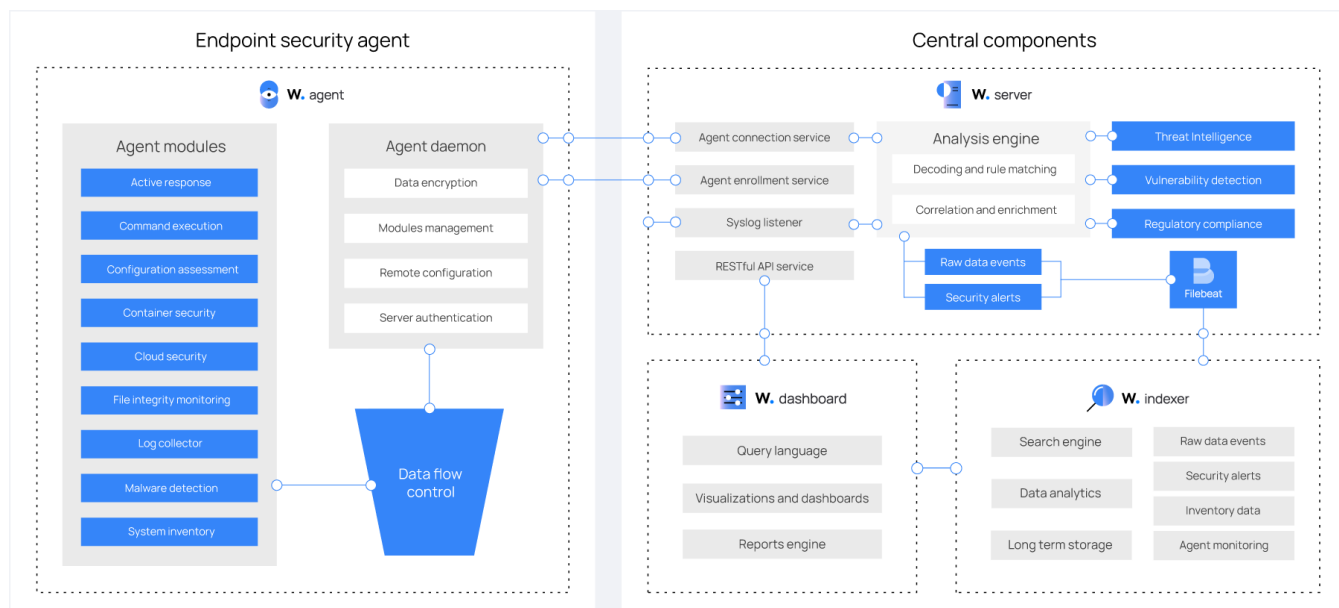
2.2.3. Các Tính năng Bảo mật khác:

- **Phát hiện xâm nhập (IDS):** Giám sát hệ thống và phát hiện các hành vi bất thường hoặc xâm nhập không mong muốn.
- **Quản lý cấu hình và chính sách:** Đảm bảo tính tuân thủ chính sách bảo mật bằng cách kiểm tra và giám sát cấu hình thiết bị và phần mềm.
- **Phát hiện và xử lý mã độc:** Nhận diện và loại bỏ mã độc, bảo vệ hệ thống khỏi phần mềm độc hại.

2.2.4. Tích hợp Linh hoạt và Khả năng Mở rộng:

- **Kết nối đa dạng:** Wazuh có thể tích hợp với nhiều công cụ và nền tảng khác, cho phép bạn xây dựng một hệ sinh thái bảo mật toàn diện và hiệu quả.
- **API mở rộng:** API của Wazuh cho phép bạn tự động hóa các quy trình làm việc và tích hợp với các hệ thống khác, tăng cường khả năng quản lý và giám sát.
- **Mã nguồn mở:** Wazuh là một giải pháp mã nguồn mở, mang đến sự linh hoạt và khả năng tùy chỉnh cao, đáp ứng các yêu cầu cụ thể của từng tổ chức.

2.3. Kiến trúc và các thành phần của Wazuh:



Hình 8. Wazuh Architecture

Wazuh được thiết kế theo mô hình phân tán, bao gồm các thành phần chính và các thành phần hỗ trợ, làm việc cùng nhau để cung cấp khả năng giám sát và bảo mật toàn diện. Các thành phần của Wazuh gồm:

2.3.1. Wazuh Agent:

- Được cài đặt trên các điểm cuối (endpoints) cần giám sát.
- Thu thập dữ liệu nhật ký, sự kiện, thông tin bảo mật, cấu hình hệ thống, kết quả quét lỗ hổng, và dữ liệu về tính toàn vẹn của tập tin từ hệ thống cục bộ.
- Gửi dữ liệu đã thu thập về Wazuh Manager thông qua một kết nối an toàn và nhận các lệnh từ Wazuh Manager.

2.3.2. Wazuh Manager (Server):

- Thành phần trung tâm của hệ thống, thường được cài đặt trên một máy chủ chuyên dụng.
- Tiếp nhận dữ liệu từ các Wazuh Agent.
- Phân tích và tương quan dữ liệu để phát hiện các mối đe dọa, hành vi bất thường và các sự cố bảo mật.
- Cung cấp giao diện quản lý tập trung để cấu hình, giám sát và điều khiển toàn bộ hệ thống Wazuh.
- Có khả năng mở rộng linh hoạt với tính năng Clustering, cho phép dễ dàng thêm hoặc bớt các Worker node, đảm bảo khả năng xử lý hiệu quả cho các hệ thống lớn.

2.3.3. Wazuh Indexer:

- Chịu trách nhiệm lưu trữ, đánh dấu chỉ mục và hỗ trợ tìm kiếm dữ liệu đã qua xử lý.
- Có thể được cấu hình với nhiều Nodes để tối ưu hóa khả năng xử lý và truy vấn, đảm bảo hiệu suất cao và duy trì tính toàn vẹn của dữ liệu..

2.3.4. Wazuh Dashboard:

- Cung cấp giao diện đồ họa cho người dùng, giúp trực quan hóa dữ liệu và quản lý cảnh báo, báo cáo, cũng như tuân thủ dữ liệu.
- Hỗ trợ người dùng trong việc phân tích và phản ứng nhanh chóng với các cuộc tấn công thông qua giao diện thân thiện.
- Có khả năng tích hợp nhiều add-ons và plugins để tối ưu hóa việc xử lý và quản lý dữ liệu.

2.3.5. Các thành phần hỗ trợ khác:

- Wazuh Filebeat:

- Một tác nhân nhẹ được sử dụng để chuyển tiếp dữ liệu nhật ký từ các nguồn khác nhau đến Wazuh Manager hoặc Elastic Stack.
- Đặc biệt hữu ích trong các mô hình triển khai phân tán, nơi Wazuh Manager không thể trực tiếp kết nối đến tất cả các nguồn dữ liệu.

- Wazuh API:

- Cung cấp một giao diện lập trình ứng dụng (API) để tích hợp Wazuh với các công cụ và hệ thống khác.
- Cho phép tự động hóa các tác vụ, truy vấn dữ liệu và mở rộng chức năng của Wazuh.

- Wazuh Ruleset:

- Một tập hợp các quy tắc được xác định trước để phát hiện các mối đe dọa và các hành vi bất thường.
- Các quy tắc này có thể được tùy chỉnh để phù hợp với môi trường và yêu cầu bảo mật cụ thể của tổ chức.

- Wazuh Modules:

- Các mô-đun mở rộng cung cấp các chức năng bổ sung như tích hợp với các công cụ bảo mật khác, giám sát các ứng dụng cụ thể hoặc thực hiện các tác vụ tùy chỉnh.

2.4. Luật trong Wazuh:

Luật (rules) là một phần vô cùng quan trọng trong Wazuh, nó chính là cốt lõi trong việc đảm bảo hệ thống Wazuh có được hoạt động theo quy trình, chính xác và hiệu quả hay không. Các luật được hệ thống sử dụng để phát hiện các cuộc tấn công xâm nhập, sự cố cấu hình, phần mềm độc hại, rootkits,...

2.4.1. Các cấp độ luật của Wazuh:

Wazuh có 16 cấp độ luật

Bảng các cấp độ luật trong Wazuh

Mức độ	Tiêu đề	Mô tả
0	<i>Ignored</i>	Không thực hiện hành động nào. Được sử dụng để tránh cảnh báo giả. Khi gặp luật có cấp độ này thì sẽ không có thông báo. Các luật này được quét trước tất cả các luật khác. Chúng bao gồm các sự kiện không có sự liên quan về bảo mật.
1	<i>None</i>	
2	<i>System low priority notification</i>	Thông báo hệ thống hoặc thông báo trạng thái. Không có sự liên quan về bảo mật.
3	<i>Successful/Authorized events</i>	Bao gồm các lần đăng nhập thành công, tường lửa cho phép sự kiện, v.v.
4	<i>System low priority error</i>	Các lỗi liên quan đến cấu hình hoặc thiết bị/ứng dụng không sử dụng. Chúng không có sự liên quan về bảo mật và thường được gây ra bởi các cài đặt mặc định hoặc kiểm thử phần mềm.

5	<i>User generated error</i>	Chúng bao gồm mật khẩu bị bỏ lỡ, hành động bị từ chối, v.v. Chính chúng không có sự liên quan về bảo mật.
6	<i>Low relevance attack</i>	Chúng chỉ ra một con sâu hoặc virus không ảnh hưởng đến hệ thống (như mã màu đỏ cho các máy chủ apache, vv). Chúng cũng bao gồm các sự kiện IDS thường xuyên và các lỗi thường xuyên.
7	<i>“Bad word” matching</i>	Chúng bao gồm các từ như "bad", "error", v.v. Những sự kiện này hầu như không được phân loại và có thể có một số mức độ liên quan về bảo mật
8	<i>First time seen</i>	Bao gồm các sự kiện lần đầu tiên được xem. Lần đầu tiên một sự kiện IDS được kích hoạt hoặc lần đầu tiên người dùng đăng nhập. Nếu bạn mới bắt đầu sử dụng OSSEC HIDS, những thông báo này có thể sẽ thường xuyên. Sau một thời gian sẽ giảm dần, Nó cũng bao gồm các hành động bảo mật có liên quan (như bắt đầu của một sniffer)
9	<i>Error from invalid source</i>	Bao gồm các lần đăng nhập dưới dạng người dùng không xác định hoặc từ nguồn không hợp lệ. Có thể có sự liên quan về bảo mật (đặc biệt nếu được lặp lại). Chúng cũng bao gồm các lỗi liên quan đến tài khoản "quản trị" (root)

10	<i>Multiple user generated errors</i>	Chúng bao gồm nhiều mật khẩu không hợp lệ, nhiều lần đăng nhập không thành công, v.v. Họ có thể chỉ ra một cuộc tấn công hoặc có thể chỉ là người dùng vừa quên thông tin đăng nhập của mình
11	<i>Integrity checking warning</i>	Chúng bao gồm các thông báo liên quan đến việc sửa đổi các tệp nhị phân hoặc sự hiện diện của rootkit (bằng kiểm tra root). Nếu bạn chỉ cần sửa đổi cấu hình hệ thống của bạn, bạn sẽ được báo về các thông báo "syscheck". Nó có thể chỉ ra một cuộc tấn công thành công. Cũng bao gồm các sự kiện IDS sẽ bị bỏ qua (số lần lặp lại cao)
12	<i>High importancy event</i>	Chúng bao gồm các thông báo lỗi hoặc cảnh báo từ hệ thống, hạt nhân, v.v. Chúng có thể chỉ ra một cuộc tấn công chống lại một ứng dụng cụ thể
13	<i>Unusual error (high importance)</i>	Hầu hết các lần khớp với một kiểu tấn công chung.
14	<i>High importance security event</i>	Hầu hết thời gian được thực hiện với sự tương quan và nó chỉ ra một cuộc tấn công.
15	<i>Severe attack</i>	Cần chú ý ngay lập tức.

Bảng 2.Các cấp độ luật trong Wazuh

Luật trong Wazuh được hỗ trợ quản lý theo nhóm, các bộ luật được xây dựng sẵn trong hệ thống Wazuh thuộc 12 nhóm sau:

- invalid_login
- authentication_success
- authentication_failed
- connection_attempt
- attacks
- adduser
- sshd
- ids
- firewall
- squid
- apache
- syslog

Đặc biệt: admin có thể tự tạo một group chứa một hoặc nhiều bộ luật mới.

Một vài thuộc tính của một luật trong Wazuh:

- Level (bắt buộc phải có): thể hiện mức độ của luật, Wazuh có 16 cấp độ từ 0-15.
- ID (bắt buộc phải có): id của luật, mỗi luật sẽ có một id riêng biệt không trùng lặp và là 1 trong các số từ 100-99999. (Khi tạo một luật mới nên đặt id từ khoảng 100.000 đến 120000).
- Maxsize: chỉ định kích thước tối đa của sự kiện thu thập, là một trong các số từ 1-99999.
- Frequency: chỉ định số lần luật được kiểm tra trước khi thực hiện. Số lần kích hoạt phải gấp đôi số lần cài đặt. Ví dụ: tần số = 2 thì luật phải được so sánh 4 lần.
- Timeframe: khung thời gian tính bằng giây, được sử dụng để kết hợp với frequency.
- Ignore: thời gian (tính bằng giây) bỏ qua rule này.
- Overwrite: Cho phép chỉnh sửa luật.

2.4.2. Phân loại luật:

Trong Wazuh, luật được chia thành 2 loại: Luật nguyên tố và luật kết hợp:

Luật nguyên tố-các luật xử lý một sự kiện, cảnh báo, thông báo hay hành động ứng phó sẽ xuất hiện khi có một sự kiện thỏa mãn. Ví dụ: Bao nhiêu lần đăng nhập thất bại sẽ xuất hiện bấy nhiêu lần thông báo.

```
<rule id="100000" level="7">  
<listlookup="match_key" field="srcip">path/to/list/file</list>  
<description>Checking srcip against cdb list file</description>  
</rule>
```

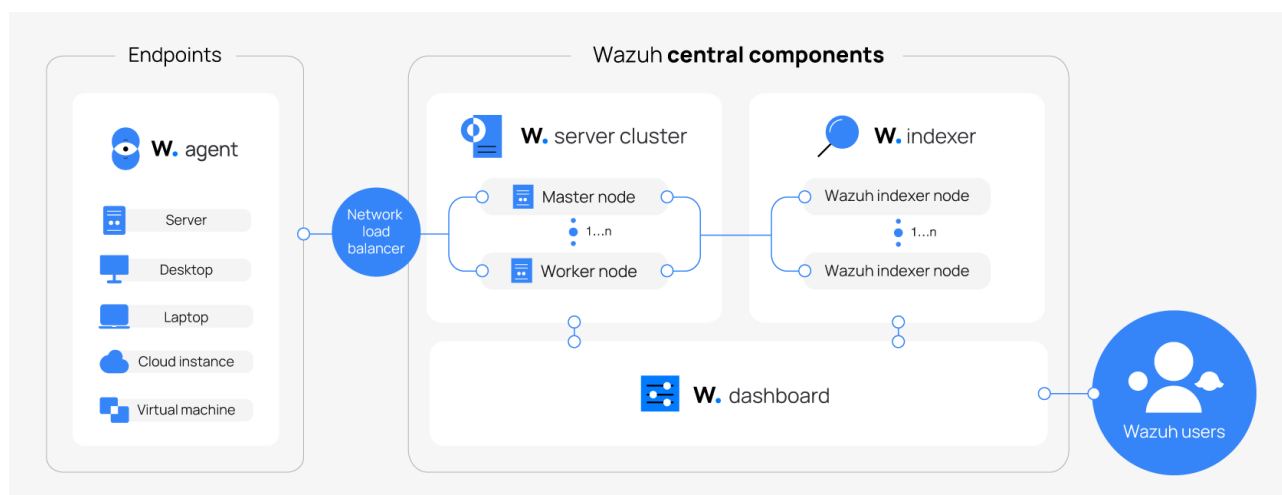
- Luật kết hợp-xử lý nhiều sự kiện một lúc trong một luật:

Có thể sử dụng với thẻ Frequency và Timeframe để xử lý một sự kiện được diễn ra nhiều lần.

Các luật được kết hợp với nhau thông qua id, sử dụng thẻ <if_sid> hoặc (<if_matched_sid> hoặc <same_id> hoặc <same_source_ip>-các thẻ này được kết hợp với Frequency và Timeframe).

```
<rule id="100103" level="7">  
<if_sid>100102</if_sid>  
<match>^Failed</match>  
<description>Fakeinc Custom: Failedpassword</description>  
</rule>
```

2.5. Wazuh hoạt động như thế nào ?



Hình 9. How Wazuh work

Quy trình hoạt động của Wazuh trải qua 5 bước:

Bước 1. Thu thập dữ liệu:

- **Wazuh Agent:** Các Wazuh Agent được cài đặt trên các điểm cuối (endpoints) khác nhau như máy chủ, máy tính để bàn, máy tính xách tay, instances đám mây và máy ảo. Chúng chịu trách nhiệm thu thập dữ liệu nhật ký hệ thống, nhật ký ứng dụng, thông tin về các tiến trình đang chạy, cấu hình hệ thống, kết quả quét lỗ hổng bảo mật và dữ liệu về tính toàn vẹn của tệp tin từ hệ thống cục bộ.

Bước 2. Truyền dữ liệu:

- **Wazuh Agent:** Các Agent sẽ gửi dữ liệu đã thu thập về Wazuh Manager thông qua một kết nối an toàn.
- **Network Load Balancer:** Trong trường hợp có nhiều Wazuh Manager, bộ cân bằng tải mạng sẽ phân phối đều lưu lượng dữ liệu từ các Agent đến các Manager, đảm bảo hệ thống hoạt động hiệu quả và cân bằng tải.

Bước 3. Xử lý và phân tích dữ liệu:

- Wazuh Server Cluster:

- **Master Node:** Đây là nút chính trong cụm máy chủ Wazuh, chịu trách nhiệm quản lý cấu hình của toàn bộ hệ thống và phân phối công việc cho các Worker Node.
- **Worker Node:** Các nút này tiếp nhận dữ liệu từ Master Node và thực hiện phân tích dữ liệu dựa trên các quy tắc (rules) được định nghĩa trước. Các quy tắc này giúp phát hiện các mối đe dọa, hành vi bất thường và các thay đổi không mong muốn trong hệ thống.

Bước 4. Lưu trữ và lập chỉ mục dữ liệu:

- Wazuh Indexer:
- **Wazuh Indexer Node:** Dữ liệu sau khi được phân tích bởi các Worker Node sẽ được gửi đến Wazuh Indexer để lưu trữ và lập chỉ mục. Wazuh sử dụng Elasticsearch để thực hiện việc này, cho phép tìm kiếm và truy vấn dữ liệu một cách nhanh chóng và hiệu quả.

Bước 5. Trực quan hóa và tương tác:

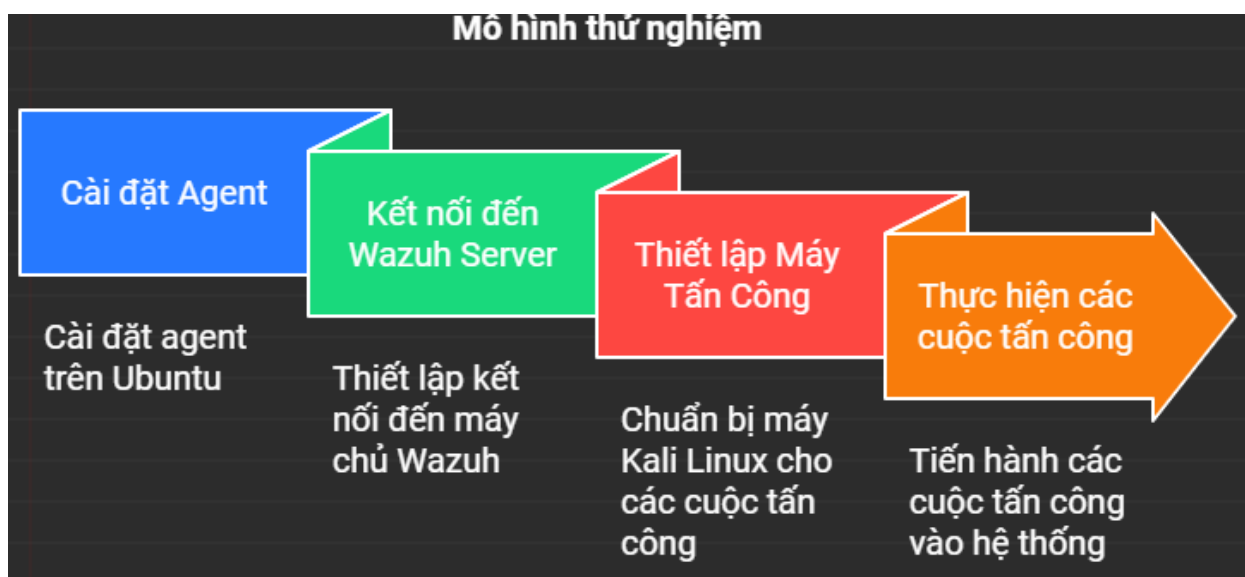
- Wazuh Dashboard:
- Dữ liệu được lưu trữ trong Wazuh Indexer được hiển thị trên Wazuh Dashboard. Giao diện này được xây dựng trên nền tảng Kibana, cung cấp các báo cáo, dashboard, biểu đồ trực quan, giúp người dùng dễ dàng giám sát và phân tích tình hình bảo mật.
- **Wazuh users:** Người dùng có thể xem các báo cáo, dashboard, thực hiện tìm kiếm, lọc, phân tích dữ liệu và nhận cảnh báo về các sự kiện bảo mật thông qua Wazuh Dashboard.

Quy trình này tạo nên một vòng tuần hoàn liên tục của việc thu thập, xử lý, lưu trữ và phân tích dữ liệu bảo mật, cho phép các tổ chức duy trì một hệ thống giám sát bảo mật toàn diện và phản ứng kịp thời với các mối đe dọa tiềm ẩn.

CHƯƠNG III. THỬ NGHIỆM VÀ ĐÁNH GIÁ

3.1. Xây dựng hệ thống:

Mô hình thử nghiệm: Mô hình bao gồm 2 agent được cài đặt trên hệ điều hành Ubuntu và Window kết nối đến một máy cài đặt Wazuh Server và một máy Attacker hệ điều hành Kali Linux để thực hiện tấn công. Về việc cài đặt mô hình thử nghiệm đã được trình bày trong Phụ lục.



Hình 10. Mô hình thử nghiệm

Cấu hình các máy trong mô hình thử nghiệm

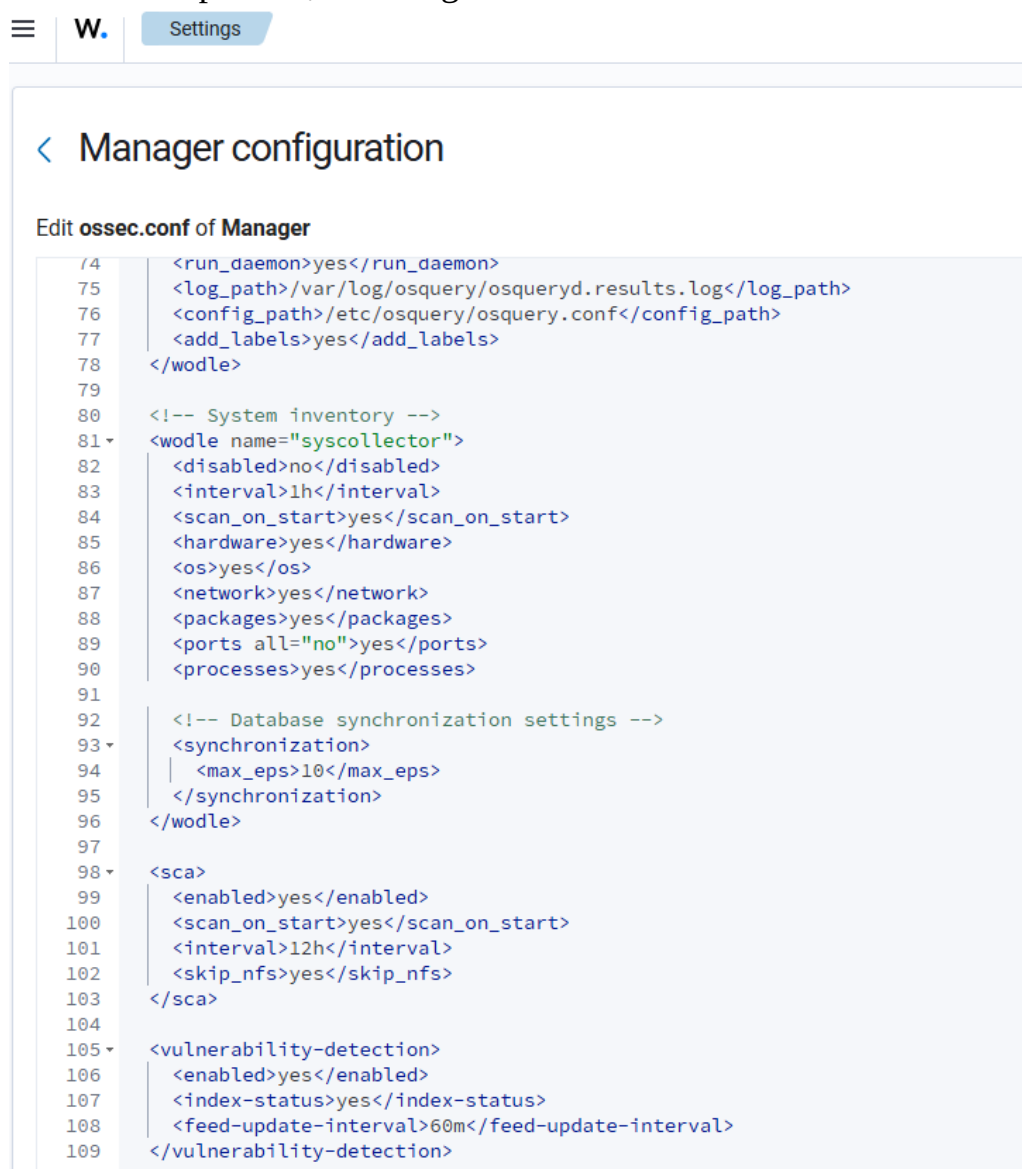
Bảng 3.Cấu hình máy ảo thử nghiệm

STT	Tên thiết bị	RAM	CPU	SSD
1	Attacker	2GB	2 core	20GB
2	Wazuh Server	4GB	4 core	40GB
3	Window10-Alex	4GB	4 core	30GB
3	Ubuntu22.04-stacy	2GB	2 core	20GB

3.2. Kịch bản 01:

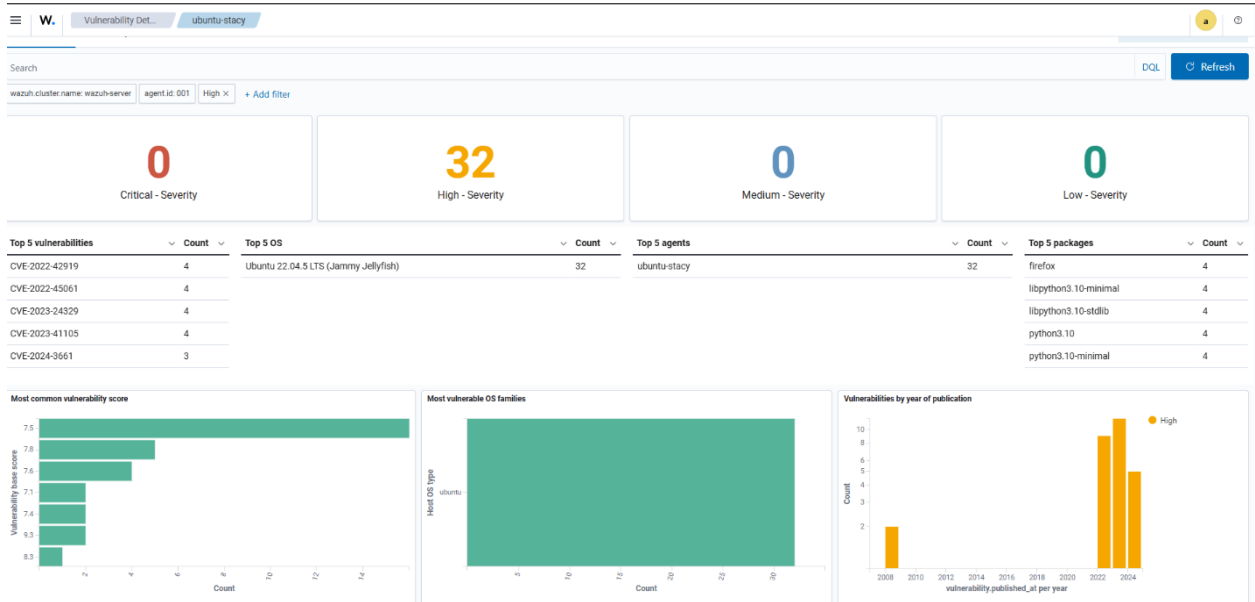
Quản trị viên dựng hệ thống có sử dụng giải pháp Wazuh và thực hiện việc quét lỗ hổng để phát hiện những lỗ hổng trên các thiết bị đã được cài đặt wazuh agent và có kết nối đến wazuh server. Hiện nay các phiên bản mới nhất của Wazuh mặc định đã bật tính năng này. Để kiểm tra lại, chúng ta mở trình sửa file theo đường dẫn `/var/ossec/etc/ossec.conf` trên wazuh server. Hoặc chúng ta có thể sửa file `ossec.conf` ngay trực tiếp trên Wazuh Dashboard

Dưới đây là đoạn cấu hình tiến trình để thu thập dữ liệu từ các agent, cũng như cấu hình trình phát hiện lỗ hổng



Hình 11. Cấu hình trong file `ossec.conf`

Dưới đây là kết quả của việc quét lỗ hổng trên các agent đã cài đặt wazuh agent. Từ dashboard này, dễ dàng nhận thấy được số lượng các lỗ hổng và mức độ các lỗ hổng đang tồn tại trong hệ thống mạng từ đó có thể đưa ra những biện pháp xử lý đối với các lỗ hổng này.



Hình 12. Dashboard lỗ hổng hệ thống

Vulnerability details

Table	JSON
t _index	wazuh-states-vulnerabilities-wazuh-server
t agent.id	001
t agent.name	ubuntu-stacy
t agent.type	wazuh
t agent.version	v4.8.2
t host.os.full	Ubuntu 22.04.5 LTS (Jammy Jellyfish)
t host.os.kernel	6.8.0-47-generic
t host.os.name	Ubuntu
t host.os.platform	ubuntu
t host.os.type	ubuntu
t host.os.version	22.04.5
t package.architecture	amd64
t package.description	Minimal subset of the Python language (version 3.10)
t package.name	python3.10-minimal
# package.size	5,902
t package.type	deb
t package.version	3.10.12-1~22.04.6
t vulnerability.category	Packages
t vulnerability.classification	CVSS
t vulnerability.description	An issue was discovered in Python 3.11 through 3.11.4. If a path containing '\0' bytes is passed to os.path.normpath(), the path will be truncated unexpectedly at the first '\0' byte. There are plausible cases in which an application would have

Hình 13. Log của một lỗ hổng được phát hiện (1)

Vulnerability details

t	package.description	minimal subset of the python language (version 3.10)
t	package.name	python3.10-minimal
#	package.size	5,902
t	package.type	deb
t	package.version	3.10.12-1~22.04.6
t	vulnerability.category	Packages
t	vulnerability.classification	CVSS
t	vulnerability.description	An issue was discovered in Python 3.11 through 3.11.4. If a path containing '\0' bytes is passed to os.path.normpath(), the path will be truncated unexpectedly at the first '\0' byte. There are plausible cases in which an application would have rejected a filename for security reasons in Python 3.10.x or earlier, but that filename is no longer rejected in Python 3.11.x.
📅	vulnerability.detected_at	Nov 22, 2024 @ 23:29:24.998
t	vulnerability.enumeration	CVE
t	vulnerability.id	CVE-2023-41105
📅	vulnerability.published_at	Aug 23, 2023 @ 14:15:08.000
t	vulnerability.reference	https://github.com/python/cpython/issues/106242 , https://github.com/python/cpython/pull/107981 , https://github.com/python/cpython/pull/107982 , https://github.com/python/cpython/pull/107983 , https://security.netapp.com/advisory/ntap-20231006-0015/ , https://mail.python.org/archives/list/security-announce%40python.org/thread/D6CDW3ZC5D444YGL3VQUY6D4ECMCQLD/
t	vulnerability.scanner.vendor	Wazuh
#	vulnerability.score.base	7.5
t	vulnerability.score.version	3.1
t	vulnerability.severity	High
t	wazuh.cluster.name	wazuh-server
t	wazuh.schema.version	1.0.0

Hình 14. Log của một lỗ hổng được phát hiện (2)

Vulnerability details

```

"agent": {
  "id": "001",
  "name": "ubuntu-stacy",
  "type": "wazuh",
  "version": "v4.8.2"
},
"host": {
  "os": {
    "full": "Ubuntu 22.04.5 LTS (Jammy Jellyfish)",
    "kernel": "6.8.0-47-generic",
    "name": "Ubuntu",
    "platform": "ubuntu",
    "type": "ubuntu",
    "version": "22.04.5"
  }
},
"package": {
  "architecture": "amd64",
  "description": "Minimal subset of the Python language (version 3.10)",
  "name": "python3.10-minimal",
  "size": 5902,
  "type": "deb",
  "version": "3.10.12-1~22.04.6"
},
"vulnerability": {
  "category": "Packages",
  "classification": "CVSS",
  "description": "An issue was discovered in Python 3.11 through 3.11.4. If a path containing '\\0' bytes is passed to os.path.normpath(), the path will be truncated unexpectedly at the first '\\0' byte. There are plausible cases in which an application would have rejected a filename for security reasons in Python 3.10.x or earlier, but that filename is no longer rejected in Python 3.11.x.",
  "detected_at": "2024-11-22T16:29:24.998Z",
  "enumeration": "CVE",
  "id": "CVE-2023-41105",
  "published_at": "2023-08-23T07:15:08Z",
  "reference": "https://github.com/python/cpython/issues/106242, https://github.com/python/cpython/pull/107981, https://github.com/python/cpython/pull/107982, https://github.com/python/cpython/pull/107983, https://security.netapp.com/advisory/ntap-20231006-0015/, https://mail.python.org/archives/list/security-announce@python.org/thread/D6CDW3ZC5D444YGL3VQUY6D4ECMCQLD/",
  "scanner": {
    "vendor": "Wazuh"
  },
  "score": {
    "base": 7.5,
    "modified": "3.1"
  }
}

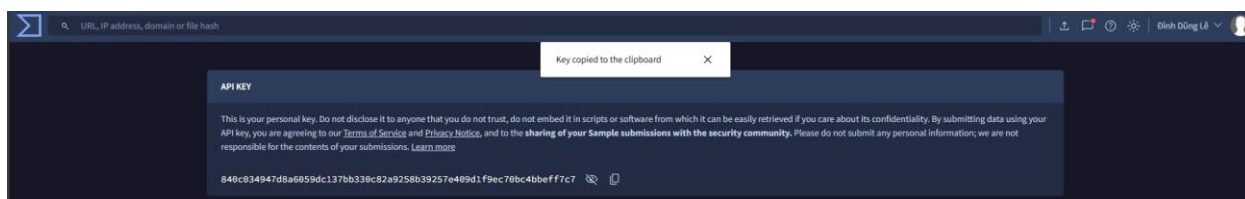
```

Hình 15. Thông tin JSON của lỗ hổng

3.3. Kịch bản 02:

Trên các client đã được cài agent sẽ giám sát những thư mục quan trọng và được chỉ định. Giả định, attacker đã chiếm quyền điều khiển của client và sửa đổi dữ liệu trong thư mục đã được giám sát. Ngoài ra, attacker còn đưa vào thư mục giám sát một file có chứa mã độc.

Đầu tiên, chúng ta cần tích hợp Virus Total vào hệ thống wazuh



Hình 16. Đăng ký nhận API của Virus Total miễn phí

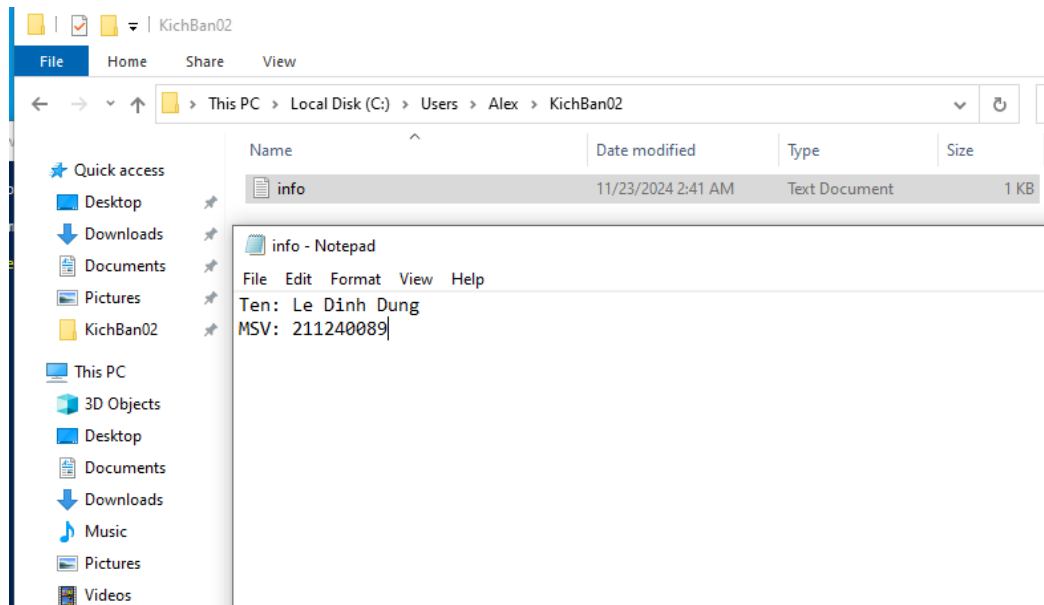
Sau khi đăng ký tài khoản Virus Total và nhận được API miễn phí, chúng ta cần cấu hình thêm API trong tệp `/var/ossec/etc/ossec.conf` để có thể tích hợp Virus Total vào wazuh server

```
<integration>
<name>virustotal</name>
<api_key>840c034947d8a6059dc137bb330c82a9258b39257e409d1f9ec70bc4bbeff7c7</api_key>
<group>syscheck</group>
<alert_format>json</alert_format>
</integration>
```

Tiếp theo, chúng ta sẽ tạo thư mục KichBan02 và cấu hình giám sát các thư mục đó trên agent.

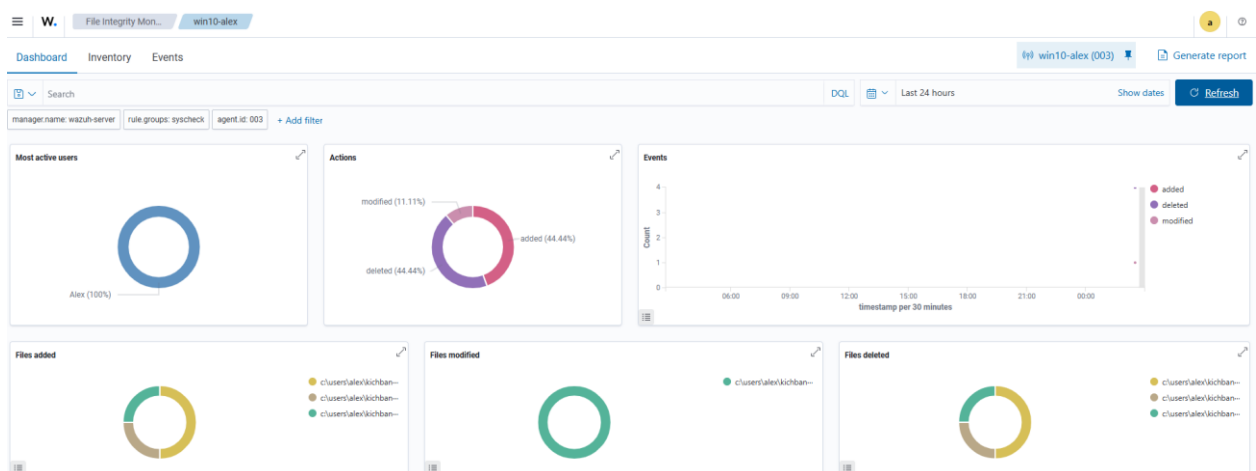
```
<syscheck>
<directories check_all="yes" report_changes="yes" realtime="yes" whodata="yes" >
C:\Users\Alex\KichBan02</directories>
</syscheck>
```

Sau khi cấu hình giám sát thư mục, chúng ta tạo một tệp text trong thư mục KichBan02

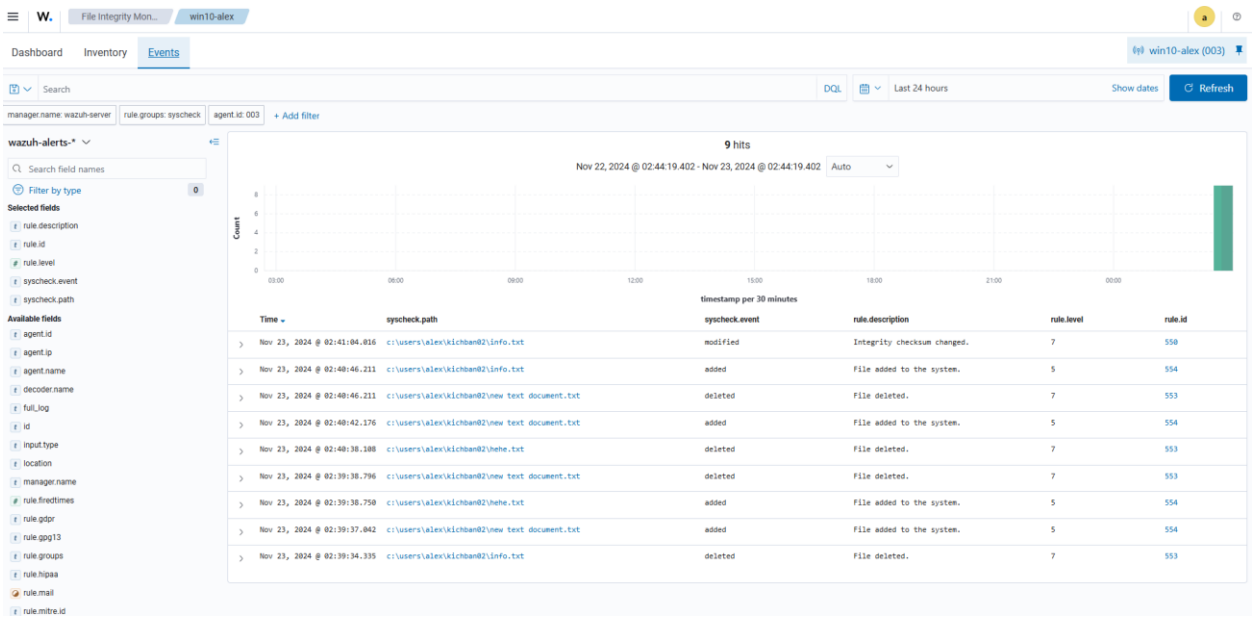


Hình 17. Tạo file trong thư mục

Kiểm tra trên dashboard, dễ dàng nhận thấy thông tin về việc tạo tệp mới trong thư mục được giám sát.



Hình 18. Thông tin hiển thị việc thêm file trên dashboard (1)



Hình 19. Thông tin hiển thị việc thêm file trên dashboard (2)

📁

Expanded document

Table	JSON
	⌕ 🔍 📄 📄 ⌘ _index wazuh-alerts-4.x-2024.11.22 ⌘ agent.id 003 ⌘ agent.ip 192.168.9.128 ⌘ agent.name win10-alex ⌘ decoder.name syscheck_new_entry ⌘ full_log File 'c:\users\alex\kichban02\info.txt' added Mode: whodata ⌘ id 1732304446.2468789 ⌘ input.type log ⌘ location syscheck ⌘ manager.name wazuh-server ⌘ rule.description File added to the system. # rule.firedtimes 4 ⌘ rule.gdpr II_5.1.f ⌘ rule.gpg13 4.11 ⌘ rule.groups ossec, syscheck, syscheck_entry_added, syscheck_file ⌘ rule.hipaa 164.312.c.1, 164.312.c.2 ⌘ rule.id 554 # rule.level 5 🔵 rule.mail false

Hình 20. Log thêm file được ghi lại trên hệ thống

Kiểm tra thông tin trong log, chúng ta có thể đọc được dữ liệu mới thêm.

```
f syscheck.audit.process.name C:\Windows\System32\notepad.exe

f syscheck.audit.user.id S-1-5-21-817407492-797142844-3412100222-1001

f syscheck.audit.user.name Alex

f syscheck.changed_attributes size, mtime, md5, sha1, sha256

f syscheck.diff ---
> Ten: Le Dinh Dung
> MSV: 211240089

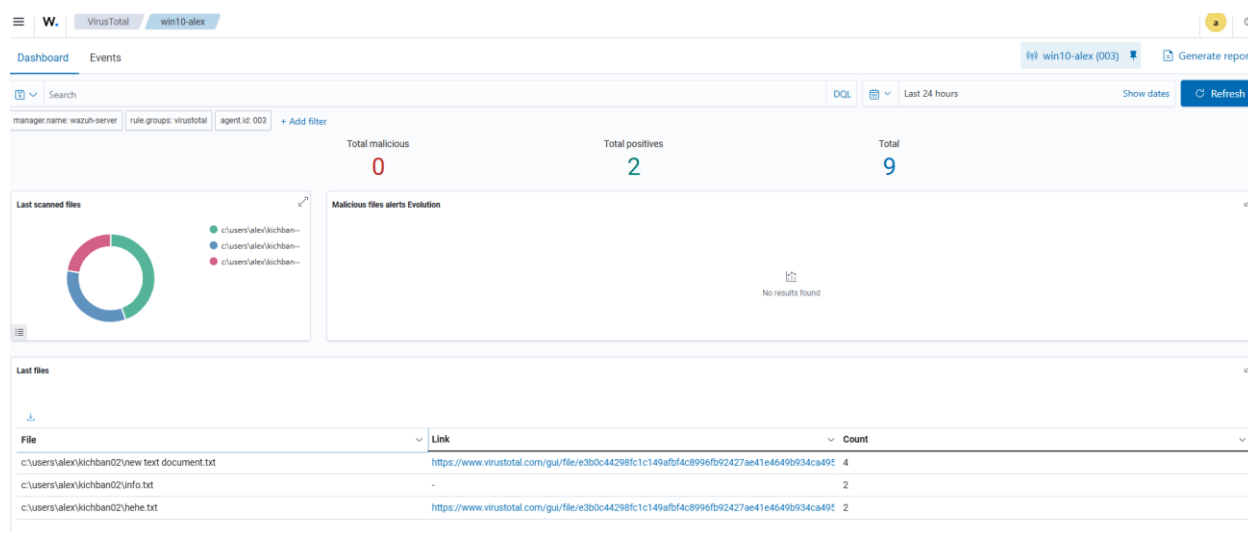
f syscheck.event modified

f syscheck.md5_after 0b75353035b584a7ac8a25cb8202a3fb

f syscheck.md5_before d41d8cd98f00b204e9800998ecf8427e
```

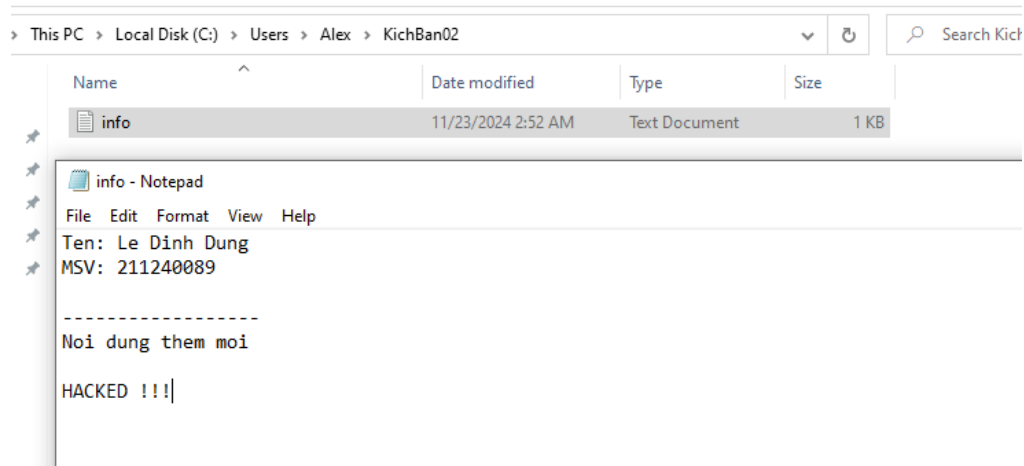
Hình 21. Nội dung dữ liệu được viết trong file

Sau attacker khi thêm file mới, Virus Total được tích hợp trong hệ thống tự động kiểm tra dữ liệu và đưa ra kết luận tệp đó có chứa mã độc hay không.



Hình 22. Virus Total tự động kiểm tra mã độc trong file mới được thêm

Attcker chiếm quyền điều khiển máy tính đã thực hiện hành vi sửa đổi dữ liệu trong tệp tin.



Hình 23. Sửa nội dung tệp tin

Khi attacker sửa đổi nội dung của tệp nằm trong thư mục đã được giám sát, hệ thống ghi lại những thông tin quan trọng liên quan đến việc sửa đổi như chương trình thực hiện sửa đổi, tài khoản thực hiện sửa đổi và quan trọng nhất đó là nội dung sửa đổi.

```
f syscheck.audit.process.name C:\Windows\System32\notepad.exe

f syscheck.audit.user.id S-1-5-21-817407492-797142844-3412100222-1001

f syscheck.audit.user.name Alex

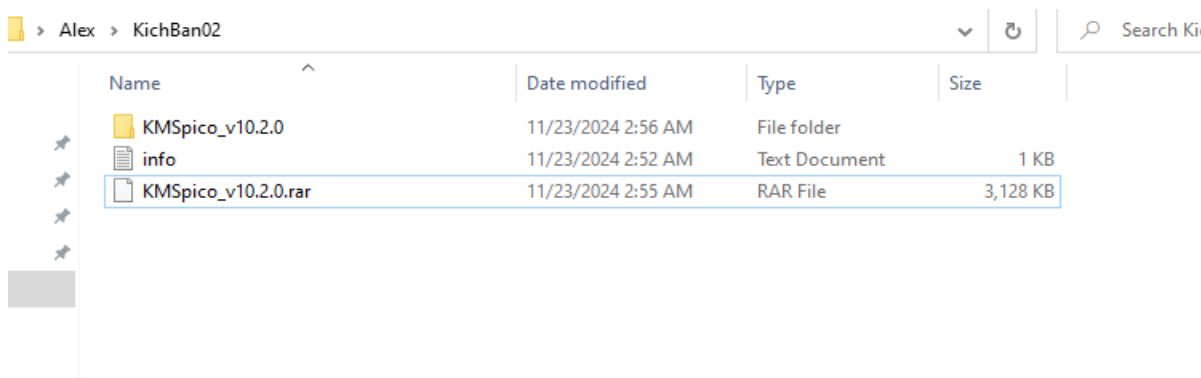
f syscheck.changed_attributes size, mtime, md5, sha1, sha256

f syscheck.diff
---
>
> -----
> Noi dung them moi
>
> HACKED !!!

f syscheck.event modified
```

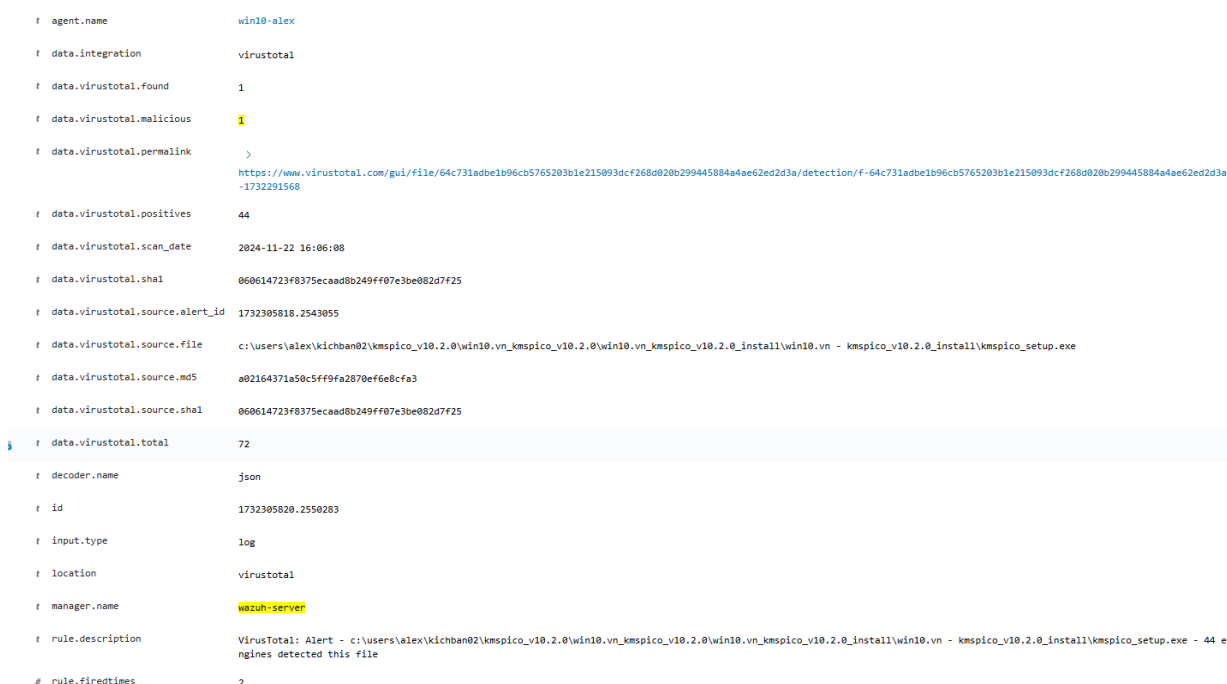
Hình 24. Thông tin về việc thay đổi nội dung file

Sau khi chỉnh sửa dữ liệu, attacker còn đưa vào thư mục những thư mục có chứa mã độc.



Hình 25. Thêm thư mục chứa mã độc

Hệ thống vừa ghi lại log của việc thêm mới thư mục và sử dụng Virus Total để kiểm tra thư mục vừa được thêm. Kết quả của việc kiểm tra là thư mục mới thêm vào có chứa mã độc. Những thông tin quan trọng được ghi lại bao gồm mã agent, IP của agent, file chứa mã độc và cảnh báo về file đó.



Hình 26. Virus Total tự động phát hiện mã độc trong thư mục mới thêm

Chúng ta có thể bấm vào link ở mục data.virustotal.permalink để có thể liên kết và xem thông tin liên quan đến file chứa mã độc trên trang web của Virus Total

44

/ 72

Community Score

-204

44/72 security vendors flagged this file as malicious

Reanalyze

Similar

More

64c731adbe1b96cb5765203b1e215093dcf268d020b299445884a4ae62ed2d3a

Size

3.08 MB

Last Analysis Date

3 hours ago

EXE

KMSpico-setup.exe

peexe

invalid-signature

signed

calls-wmi

upx

long-sleeps

checks-user-input

direct-cpu-clock-access

detect-debug-environment

checks-disk-space

nsis

overlay

via-tor

runtime-modules

DETECTION

DETAILS

RELATIONS

ASSOCIATIONS

BEHAVIOR

COMMUNITY 30+

Crowdsourced YARA rules

Matches rule **INDICATOR_EXE_Packed_Dotfuscator** from ruleset **indicator_packed** at <https://github.com/ditekshen/detection> by **ditekSHen**

↳ Detects executables packed with Dotfuscator

Matches rule **UPX** from ruleset **UPX** at <https://github.com/kevoreilly/CAPEv2> by **kevoreilly**

↳ UPX dump on OEP (original entry point)

Matches rule **IcedID** from ruleset **IcedID** at <https://github.com/kevoreilly/CAPEv2> by **kevoreilly, threatlive**

↳ IcedID Payload

Matches rule **WinDivert_Driver** from ruleset **gen_pua** at <https://github.com/Neo23x0/signature-base> by **Florian Roth (Nextron Systems)**

↳ Detects WinDivert User-Mode packet capturing driver

Matches rule **NSIS** from ruleset **NSIS** at <https://github.com/kevoreilly/CAPEv2> by **kevoreilly**

↳ NSIS Integrity Check function

Matches rule **Multifamily_RAT_Detection** from ruleset **rat_detection** at <https://github.com/securitymagic/yara> by **Lucas Acha** (<http://www.lukeacha.com>)

↳ Generic Detection for multiple RAT families, PUPs, Packers and suspicious executables

See all

Hình 27. Kiểm tra thông tin trên Virus Total

44

3.4. Kịch bản 03:

Attacker tấn công SSH brute force vào client với địa chỉ IP là 192.168.9.130. Khi bị tấn công, wazuh sẽ chạy các lệnh trên agent để phản ứng lại cuộc tấn công vào client.

Để có thể chủ động phản ứng với cuộc tấn công, ở đây chúng ta sẽ cấu hình “active response” – Wazuh sử dụng mô-đun phản hồi tích cực để chạy các tập lệnh hoặc tệp thực thi trên điểm cuối được giám sát, thực hiện hành động để có thể bảo vệ client kịp thời.

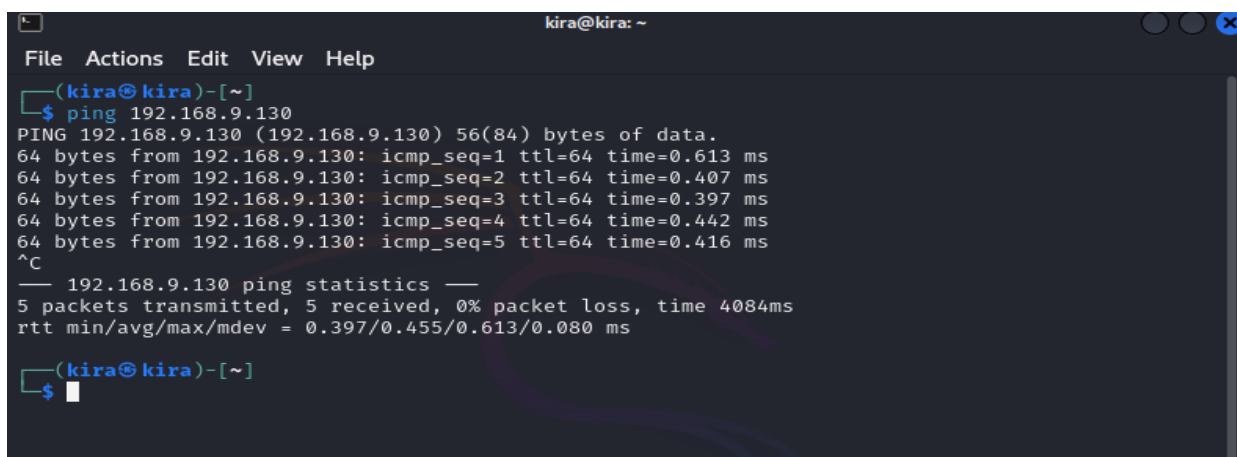
Khi xác định được lúc nào phản ứng chủ động với cuộc tấn công SSH¹⁰ brute force, cần phải có tập lệnh để hoạt động.

```
<command>
  <name>firewall-drop</name>
  <executable>firewall-drop</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>
```

Cuối cùng, chúng ta cấu hình wazuh để chạy các phản ứng:

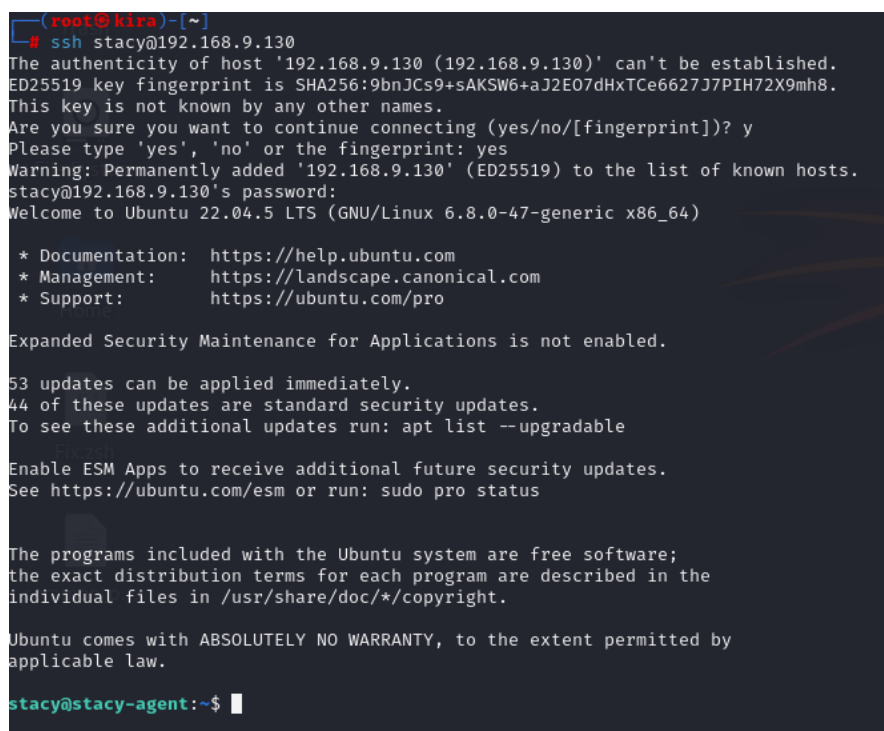
```
<ossec_config>
  <active-response>
    <command>firewall-drop</command>
    <location>local</location>
    <rules_id>5763</rules_id>
    <timeout>180</timeout>
  </active-response>
</ossec_config>
```

Kiểm tra kết nối từ máy Attacker đến ubuntu agent



```
kira@kira: ~  
File Actions Edit View Help  
(kira@kira)-[~]  
$ ping 192.168.9.130  
PING 192.168.9.130 (192.168.9.130) 56(84) bytes of data.  
64 bytes from 192.168.9.130: icmp_seq=1 ttl=64 time=0.613 ms  
64 bytes from 192.168.9.130: icmp_seq=2 ttl=64 time=0.407 ms  
64 bytes from 192.168.9.130: icmp_seq=3 ttl=64 time=0.397 ms  
64 bytes from 192.168.9.130: icmp_seq=4 ttl=64 time=0.442 ms  
64 bytes from 192.168.9.130: icmp_seq=5 ttl=64 time=0.416 ms  
^C  
--- 192.168.9.130 ping statistics ---  
5 packets transmitted, 5 received, 0% packet loss, time 4084ms  
rtt min/avg/max/mdev = 0.397/0.455/0.613/0.080 ms  
(kira@kira)-[~]  
$
```

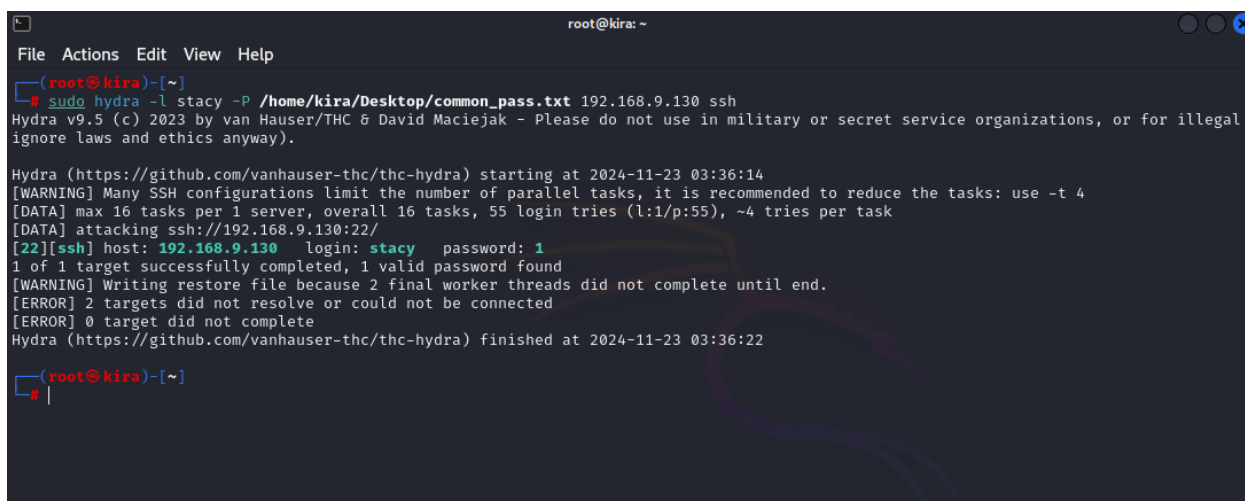
Hình 28. Kiểm tra kết nối mạng giữa máy Attacker và ubuntu agent



```
(root@kira)-[~]  
# ssh stacy@192.168.9.130  
The authenticity of host '192.168.9.130 (192.168.9.130)' can't be established.  
ED25519 key fingerprint is SHA256:9bnJCs9+sAKSW6+aJ2E07dHxTCe6627J7PIH72X9mh8.  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? y  
Please type 'yes', 'no' or the fingerprint: yes  
Warning: Permanently added '192.168.9.130' (ED25519) to the list of known hosts.  
stacy@192.168.9.130's password:  
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-47-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
Expanded Security Maintenance for Applications is not enabled.  
  
53 updates can be applied immediately.  
44 of these updates are standard security updates.  
To see these additional updates run: apt list --upgradable  
  
Enable ESM Apps to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
stacy@stacy-agent:~$
```

Hình 29. Thực hiện SSH từ máy Attacker đến máy agent

Trên máy Attacker, chúng ta sẽ sử dụng tool Hydra để thực hiện tấn công brute-force, với file common_pass.txt chứa những mật khẩu có khả năng là của client



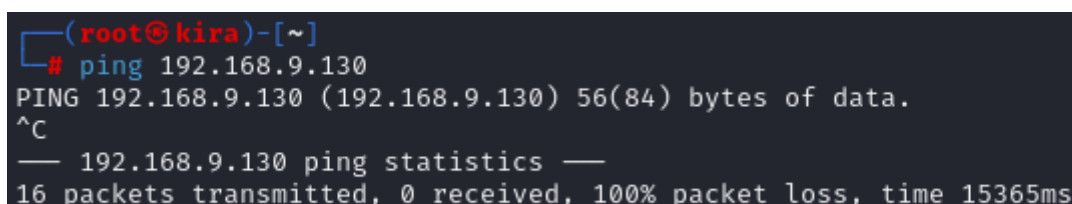
```
root@kira: ~
File Actions Edit View Help
(root@kira)-[~]
# sudo hydra -l stacy -P /home/kira/Desktop/common_pass.txt 192.168.9.130 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal
ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-23 03:36:14
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 55 login tries (l:1/p:55), ~4 tries per task
[DATA] attacking ssh://192.168.9.130:22/
[22][ssh] host: 192.168.9.130 login: stacy password: 1
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-23 03:36:22

(root@kira)-[~]
#
```

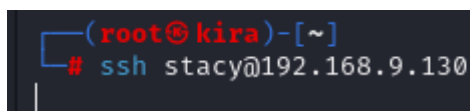
Hình 30. Thực hiện giả định tấn công SSH brute force bằng Hydra

Sau khi thực hiện giả định việc tấn công ssh brute force, hệ thống đã nhanh chóng phát hiện và thực thi phản ứng chặn lại IP của máy tính attacker. Khi đó từ máy tính của attacker không thể ping hay SSH tới máy ubuntu agent.



```
(root@kira)-[~]
# ping 192.168.9.130
PING 192.168.9.130 (192.168.9.130) 56(84) bytes of data.
^C
— 192.168.9.130 ping statistics —
16 packets transmitted, 0 received, 100% packet loss, time 15365ms
```

Hình 31. Attacker thực hiện ping đến agent



```
(root@kira)-[~]
# ssh stacy@192.168.9.130
|
```

Hình 32. Attacker SSH đến agent

Trên dashboard, quản trị viên có thể dễ dàng thấy được thông tin của việc chặn IP của kẻ tấn công

Security Alerts							
	Time ↕	Technique(s)		Tactic(s)	Description	Level	Rule ID
>	Nov 23, 2024 @ 03:51:02.880				Host Blocked by firewall-drop Active Response	3	651
>	Nov 23, 2024 @ 03:51:02.865				Host Blocked by firewall-drop Active Response	3	651
>	Nov 23, 2024 @ 03:51:00.931	T1110.001	T1021.004	Credential Access, Lateral Movement	sshd: authentication failed.	5	5760
>	Nov 23, 2024 @ 03:51:00.885	T1110.001	T1021.004	Credential Access, Lateral Movement	sshd: authentication failed.	5	5760
>	Nov 23, 2024 @ 03:51:00.885	T1110.001	T1021.004	Credential Access, Lateral Movement	sshd: authentication failed.	5	5760
>	Nov 23, 2024 @ 03:51:00.883	T1110.001	T1021.004	Credential Access, Lateral Movement	sshd: authentication failed.	5	5760

Hình 33. Log của thông tin chặn IP của Attacker (1)

data.parameters.program	active-response/bin/firewall-drop
data.scrip	192.168.9.133
data.version	1
decoder.name	ar_log_json
decoder.parent	ar_log_json
full_log	2024/11/23 03:51:00 active-response/bin/firewall-drop: {"version":1,"origin":{"name":"node01","module":"wazuh-execd"},"command":"add","parameters":{"extra_args":"","alert":{"timestamp":"2024-11-22T20:51:00.875+0000"},"rule":{"level":10,"description":"sshd: brute force trying to get access to the system. Authentication failed.":"id":"5763","mitre":{"id":"T1110"},"tactic":["Credential Access"],"technique":["Brute Force"],"frequency":8,"firedtimes":2,"mail":{"false},"groups":["syslog","sshd","authentication_failures"],"gdpr":{"IV_35.7.d","IV_32.2"},"hipaa":{"164.312.b"},"nist_800_53":{"SI.4","AU.14","AC.7"},"pci_dss":{"11.4","10.2.4","10.2.5"},"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"},"agent":{"id":"002","name":"ubuntu-stacy","ip":"192.168.9.130"},"manager":{"name":"wazuh-server"},"id":"1732308660.3047352","previous_output":"Nov 23 03:51:00 stacy-agent sshd[6162]: Failed password for stacy from 192.168.9.133 port 37142 ssh2\nNov 23 03:51:00 stacy-agent sshd[6156]: Failed password for stacy from 192.168.9.133 port 37102 ssh2\nNov 23 03:51:00 stacy-agent sshd[6160]: Failed password for stacy from 192.168.9.133 port 37128 ssh2\nNov 23 03:51:00 stacy-agent sshd[6157]: Failed password for stacy from 192.168.9.133 port 37110 ssh2\nNov 23 03:51:00 stacy-agent sshd[6154]: Failed password for stacy from 192.168.9.133 port 37086 ssh2\nNov 23 03:51:00 stacy-agent sshd[6152]: Failed password for stacy from 192.168.9.133 port 37056 ssh2\nNov 23 03:51:00 stacy-agent sshd[6153]: Failed password for stacy from 192.168.9.133 port 37074 ssh2","full_log":"Nov 23 03:51:00 stacy-agent sshd[6151]: Failed password for stacy from 192.168.9.133 port 37058 ssh2"},"predecoder":{"program_name":"sshd","timestamp":"Nov 23 03:51:00","hostname":"stacy-agent"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"scrip":"192.168.9.133","srcport":"37058","dstuser":"stacy"},"location":"/var/log/auth.log"},"program":"active-response/bin/firewall-drop"}}
id	1732308662.3054548
input.type	log
location	/var/ossec/logs/active-responses.log
manager.name	wazuh-server
rule.description	Host Blocked by firewall-drop Active Response
rule.firedtimes	4
rule.gdpr	IV_35.7.d
rule.gpg13	4.13
rule.groups	ossec, active_response
rule.id	651
rule.level	3

Hình 34. Log của thông tin chặn IP của Attacker (2)

3.5. Đánh giá và kết luận:

Dựa trên kết quả thu được từ ba kịch bản thử nghiệm, Wazuh chứng tỏ năng lực vượt trội trong việc phát hiện và xử lý các sự kiện bất thường, đồng thời thể hiện những ưu điểm nổi bật sau:

- **Triển khai dễ dàng:** Wazuh sở hữu quy trình cài đặt và cấu hình đơn giản, trực quan, tương thích với đa dạng nền tảng hệ điều hành. Giao diện quản lý tập trung giúp người dùng dễ dàng giám sát và vận hành hệ thống.
- **Khả năng mở rộng linh hoạt:** Kiến trúc Wazuh cho phép điều chỉnh quy mô hệ thống một cách linh hoạt, đáp ứng nhu cầu giám sát của các hệ thống từ nhỏ đến lớn, đảm bảo khả năng thích ứng cao.
- **Cộng đồng hỗ trợ mạnh mẽ:** Là một giải pháp mã nguồn mở, Wazuh được hỗ trợ bởi cộng đồng người dùng và nhà phát triển đông đảo, cung cấp kho tài liệu hướng dẫn phong phú, hỗ trợ kỹ thuật chuyên sâu và cập nhật thường xuyên.
- **Hiệu quả về chi phí:** Wazuh là giải pháp mã nguồn mở, tối ưu hóa chi phí triển khai cho tổ chức bằng cách loại bỏ chi phí bản quyền và các khoản phí liên quan.

Tuy nhiên, bên cạnh những ưu điểm kể trên, Wazuh cũng tồn tại một số hạn chế nhất định:

- **Yêu cầu kiến thức chuyên môn:** Để cấu hình và vận hành Wazuh đạt hiệu quả tối ưu, người dùng cần có nền tảng kiến thức vững chắc về an ninh mạng và hệ thống.
- **Tùy chỉnh phức tạp:** Quá trình tùy chỉnh các quy tắc và mô-đun của Wazuh đòi hỏi người dùng am hiểu sâu về hệ thống, có thể gây khó khăn cho người dùng mới.

Kết luận:

Wazuh là một giải pháp giám sát an ninh mạng toàn diện, mạnh mẽ và hiệu quả, phù hợp với đa dạng mô hình tổ chức. Khả năng phát hiện và phản hồi nhanh chóng các mối đe dọa của Wazuh giúp tổ chức chủ động bảo vệ hệ thống và dữ liệu, đảm bảo an toàn thông tin một cách hiệu quả.

TÀI LIỆU THAM KHẢO

<https://www.cisecurity.org/solarwinds>

https://en.wikipedia.org/wiki/Colonial_Pipeline_ransomware_attack

<https://www.cm-alliance.com/cybersecurity-blog/royal-mail-ransomware-attack-timeline>

<https://documentation.wazuh.com/current/index.html>

<https://www.ossec.net/docs/>

<https://docs.splunk.com/Documentation>

<https://cdn-cybersecurity.att.com/doc-repo/OTX/user-guides/Using-USM-and-OSSIM-5.1-with-OTX.pdf>

PHỤ LỤC

1. Cài đặt Wazuh:

Wazuh hiện tại hỗ trợ cài đặt vô cùng nhanh gọn và tiện lợi, chỉ với vài dòng lệnh và thao tác. Tuy nhiên, các tổ chức hay người dùng cũng cần chú ý đến số lượng Agent mà mình sẽ quản lý để có thể chuẩn bị được tài nguyên cũng như triển khai phù hợp.

Agents	CPU	RAM	Storage (90 days)
1-25	4 vCPU	8 GiB	50 GB
25-50	8 vCPU	8 GiB	100 GB
50-100	8 vCPU	8 GiB	200 GB

Bảng 4. tài nguyên tham khảo trước khi cài Wazuh

Trên thiết bị dùng làm server (hệ điều hành Linux) ta chỉ cần chạy 1 lệnh duy nhất

```
curl -sO https://packages.wazuh.com/4.8/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
```

Sau khi hoàn tất quá trình cài đặt, đầu ra sẽ hiển thị thông tin xác thực truy cập và thông báo xác nhận rằng quá trình cài đặt đã thành công.

```
INFO: --- Summary ---
INFO: You can access the web interface https://<wazuh-dashboard-ip>
      User: admin
      Password: <ADMIN_PASSWORD>
INFO: Installation finished.
```

Hình 35. Thông báo sau khi cài đặt hoàn tất

Cuối cùng chúng ta sẽ truy cập vào Wazuh-Dashboard để quản lý trực quan hơn với đường dẫn “**https://<wazuh-dashboard-ip>**”, đăng nhập với user và password được hiển thị phía trên.

2. Cài đặt Agent:

Việc cài đặt Wazuh-Agent trên các Client muốn quản lý vô cùng đơn giản và tiện lợi. Hiện Wazuh hỗ trợ đa nền tảng như Ubuntu, Windows, MacOS nên người dùng có thể giám sát nhiều loại thiết bị khác nhau.

Ngay tại giao diện của Wazuh-Dashboard, ta ấn vào **“Deploy New Agent”**

The screenshot shows the 'Deploy new agent' page in the Wazuh Dashboard. It is divided into three numbered steps:

- 1 Select the package to download and install on your system:**
 - LINUX:** Includes radio buttons for RPM amd64, RPM aarch64, DEB amd64, and DEB aarch64.
 - WINDOWS:** Includes a radio button for MSI 32/64 bits.
 - macOS:** Includes radio buttons for Intel and Apple silicon.
 - A note at the bottom: "For additional systems and architectures, please check our [documentation](#)."
- 2 Server address:**

This is the address the agent uses to communicate with the server. Enter an IP address or a fully qualified domain name (FQDN).

Assign a server address ?

192.168.88.244

☒ Remember server address
- 3 Optional settings:**

By default, the deployment uses the hostname as the agent name. Optionally, you can use a different agent name in the field below.

Hình 36. Thao tác khi thêm 1 thiết bị để giám sát trên Wazuh (1)

✓

Optional settings:

By default, the deployment uses the hostname as the agent name. Optionally, you can use a different agent name in the field below.

Assign an agent name: ?

win10-ledinhdung

①

The agent name must be unique. It can't be changed once the agent has been enrolled. [↗](#)

Select one or more existing groups: ?

Default

4

Run the following commands to download and install the agent:

```
Invoke-WebRequest -Uri https://packages.wazuh.com/4.x/windows/wazuh-agent-4.8.2-1.msi -OutFile
${env.tmp}\wazuh-agent; msixec.exe /i ${env.tmp}\wazuh-agent /q WAZUH_MANAGER='192.168.88.244'
WAZUH_AGENT_NAME='win10-ledinhdung'
```

③

Requirements

- You will need administrator privileges to perform this installation.
- PowerShell 3.0 or greater is required.

Keep in mind you need to run this command in a Windows PowerShell terminal.

5

Start the agent:

```
NET START WazuhSvc
```

Hình 37. Thao tác khi thêm 1 thiết bị để giám sát trên Wazuh (2)

Ở đây chúng ta chỉ cần chọn đúng phiên bản OS của thiết bị cần giám sát, sau đó điền đúng các thông tin. Wazuh sẽ hỗ trợ chúng ta cài đặt bằng những câu lệnh được tạo tự động cũng như hướng dẫn vô cùng chi tiết, từ đó giúp việc cài đặt được hoàn tất nhanh chóng.